

SOC All about Data

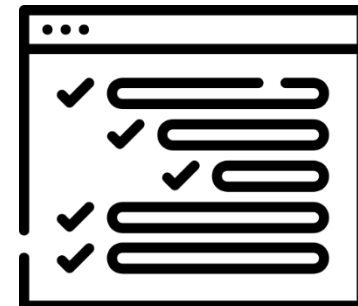
SOC.F2601

Peter Infanger, HSLU I

**DATA IS
EVERYTHING**

Inhalt

- Daten, welche Daten?
- Datenquellen:
 - Windows & Linux
 - weiteren Komponenten (Router, Firewalls, Proxy, Content-Filter, ...)
- Weitere Datenquellen auf:
 - Host & Netzwerk
- Daten Aufarbeitung (Visibility)
- Daten Normalisierung
- Daten Reduktion
- Daten Kollektoren (SIEM)



Daten, welche Daten?

- Das SOC kann ohne Daten nicht arbeiten, dazu gehören:
 - Log-Files (lokal oder zentral gesammelt)
 - Alerts / Alarme
 - Aufgezeichnete Daten (Transaktionsdaten, Packet-Captures)
 - Statistiken
 - ...
- Gewisse Daten sind aufgezeichnete, also eher historische Daten, andere wiederum sind Realtime-Daten aus dem laufenden Betrieb (z.B. Alerts)
- Mit der Kombination dieser Daten lassen sich viele Sachverhalte erkennen und ggf. sicherheitsrelevante Aktivitäten richtig einordnen und behandeln.
- Historische Daten helfen z.B. Situationen nachzuvollziehen oder Tendenzen zu erkennen.
- Mit dem Vergleich von statistischen Daten können Änderungen im Verhalten von Systemen/Netzwerken etc. erkannt werden.



Datenquellen – Logging

Möglich Datenquellen, welche die Informationen entweder lokal in Log-Files speichern oder an zentrale Log-Kollektoren schicken sind z.B.:

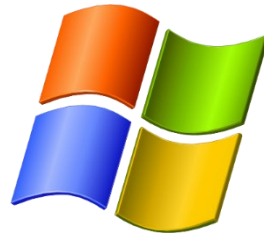
- Host-basierte Intrusion Detection Systeme (HIDS) die auf einzelnen Hosts laufen. Viele Host-basierte Schutzsysteme übermitteln Protokolle an einen zentralen Log-Server, der von einer zentralen Stelle aus mit NSM-Tools durchsucht werden kann.
- Microsoft Windows-Host-Logs sind lokal über die Ereignisanzeige sichtbar. Die Ereignisanzeige speichert vier Arten von Protokollen:
 - **Application Logs:** Diese enthalten Ereignisse, welche von verschiedenen Anwendungen protokolliert werden.
 - **System Logs:** Diese enthalten Ereignisse bezüglich des Betriebs von Treibern, Prozessen und Hardware.
 - **Setup Logs:** Diese zeichnen Informationen über die Installation von Software auf, einschliesslich Windows-Updates.
 - **Security Logs:** Diese zeichnen sicherheitsrelevante Ereignisse auf, z. B. Anmeldeversuche und Vorgänge im Zusammenhang mit der Datei- oder Objektverwaltung und dem Zugriff.
 - **Command-Line Logs:** Angreifer, die sich Zugang zu einem System verschafft haben, und einige Arten von Malware führen Befehle über die Befehlszeilenschnittstelle (CLI) und nicht über eine grafische Benutzeroberfläche aus. Die Protokollierung der Befehlszeilenausführung verschafft Einblick in diese Art von Vorfällen.



Datenquellen – Logging

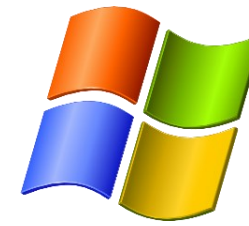
- Die Tabelle erklärt die Bedeutung der fünf Windows-Host-Log Ereignistypen.

Event Type	Description
Error	It is an event that indicates a significant problem such as loss of data or functionality. For example, if a service fails to load during startup, an error event is logged.
Warning	It is an event that is not necessarily significant but may indicate a possible future problem. For example, when disk space is low, a warning event is logged. If an application recovers from an event without loss of functionality or data, it can classify the event as a warning event.
Information	It describes the successful operation of an application, driver, or service. For example, when a network driver loads successfully, it may be appropriate to log an information event. Note that it is generally inappropriate for a desktop application to log an event each time it starts.
Success Audit	It is an event that records an audited security access attempt that is successful. For example, a user's successful attempt to log on to the system is a success audit event.
Failure Audit	It is an event that records an audited security access attempt that fails. For example, if a user tries to access a network drive and fails, the attempt is logged as a failure audit event.



Windows

- Die Windows Ereignisanzeige bzw. Event Viewer bieten Zugang zu protokolliert Verlauf von Anwendungs-, Sicherheits- und Systemereignissen.
- Diese Protokolldateien sind ein Hilfsmittel zur Fehlersuche, da sie Informationen liefern, die zur Identifizierung eines Problems erforderlich sind.
- Windows enthält zwei Kategorien von Ereignisprotokollen:
 - Windows-Protokolle und Anwendungs- und Dienstprotokolle.
- Eine eingebaute benutzerdefinierte Ansicht namens Event Viewer zeigt alle kritischen, Fehler- und Warnereignisse aus allen Verwaltungsprotokollen an.
- Sicherheitereignisprotokolle befinden sich unter Windows-Protokolle. Sie verwenden Ereignis-IDs, um die Art des Ereignisses zu identifizieren.



Windows – Event Viewer

Ereignisanzeige (Lokal)

Übersicht und Zusammenfassung Zuletzt aktualisiert: 04.03.2021 18:26:56

Übersicht

Sie können die auf dem Computer aufgetretenen Ereignisse anzeigen, indem Sie in der Konsolenstruktur den Knoten für die Quelle, das Protokoll oder die benutzerdefinierte Ansicht wählen. Die benutzerdefinierte Ansicht "Administrativ" enthält alle administrativen Ereignisse, unabhängig von der Quelle. Eine Zusammenfassung aller Protokolle wird unten angezeigt.

Zusammenfassung der administrativen Ereignisse

Ereignistyp	Ereignis...	Quelle	Protokoll	Letzte Stu...	24 Stunden	7 Tage
Kritisch	-	-	-	0	0	0
Fehler	-	-	-	0	1	11
Warnung	-	-	-	3	32	238
Informationen	-	-	-	101	375	2'923
Überwachun...	-	-	-	265	1'317	9'932

Zuletzt angezeigte Knoten

Name	Beschreib...	Geändert	Erstellt
Windows-Protokolle/An...	Nicht zutr...	04.03.2021 18:07:24	06.12.2020 08:47:29

Protokollzusammenfassung

Protokollname	Größe (Ak...	Geändert	Aktiviert	Beibehaltungsrichtlinie
Windows PowerShell	2.07 MB/1...	04.03.2021 07:05:28	Aktiviert	Ereignisse bei Bedarf üb...
System	6.07 MB/2...	04.03.2021 18:07:24	Aktiviert	Ereignisse bei Bedarf üb...
Sicherheit	20.00 MB/...	04.03.2021 18:26:52	Aktiviert	Ereignisse bei Bedarf üb...
Microsoft Office Alerts	68 KB/1.0...	03.03.2021 20:44:59	Aktiviert	Ereignisse bei Bedarf üb...
Schlüsselverwaltungsdie...	68 KB/20 ...	06.12.2020 08:48:44	Aktiviert	Ereignisse bei Bedarf üb...
Internet Explorer	68 KB/1.0...	06.12.2020 08:48:44	Aktiviert	Ereignisse bei Bedarf üb...

Aktionen

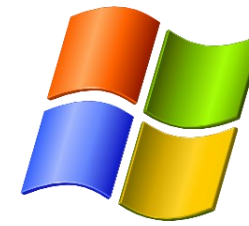
Ereignisanzeige (Lokal)

- Gespeicherte Protokolldatei öffnen...
- Benutzerdefinierte Ansicht erstellen...
- Benutzerdefinierte Ansicht importieren...
- Verbindung mit anderem Computer herstellen...

Ansicht

- Aktualisieren
- Hilfe

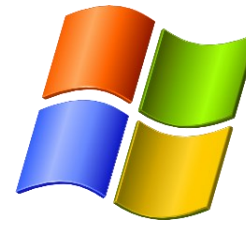




Windows - Dateisysteme

- Ein Dateisystem ist eine Möglichkeit, die Informationen auf Speichermedien zu organisieren. In der folgenden Tabelle sind die von Windows unterstützten Dateisysteme aufgeführt:

Windows File System	Description
exFAT	• This is a simple file system supported by many different operating systems. • FAT has limitations to the number of partitions, partition sizes, and file sizes that it can address, so it is not usually used for hard drives or solid-state drives anymore. • Both FAT16 and FAT32 are available to use, with FAT32 being the most common as it has many fewer restrictions than FAT16.
Hierarchical File System Plus (HFS+)	• This file system is used on MAC OS X computers and allows much longer filenames, file sizes, and partition sizes. • Although it is not supported by Windows without special software, Windows is able to read data from HFS+ partitions.
Extended File System (EXT)	• This file system is used with Linux-based computers. • Although it is not supported by Windows, Windows is able to read data from EXT partitions with special software.
New Technology File System (NTFS)	• This is the most commonly used file system when installing Windows. All versions of Windows and Linux support NTFS. • Mac-OS X computers can only read an NTFS partition. They are able to write to an NTFS partition after installing special drivers.

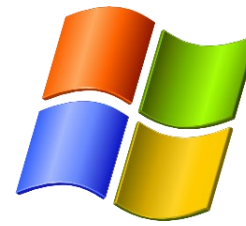


Windows - Dateisysteme

Bei der NTFS-Formatierung werden auf der Festplatte wichtige Strukturen für die Dateiablage und Tabellen für die Aufzeichnung der Speicherorte von Dateien erstellt:

- **Partition Boot Sector:** Dies sind die ersten 16 Sektoren des Laufwerks. Er enthält den Speicherort der Master File Table (MFT). Die letzten 16 Sektoren enthalten eine Kopie des Bootsektors.
- **Master File Table (MFT):** Diese Tabelle enthält die Speicherorte aller Dateien und Verzeichnisse auf der Partition, einschliesslich der Dateiattribute wie Sicherheitsinformationen und Zeitstempel.
- **System Files:** Dies sind versteckte Dateien, die Informationen über andere Volumes und Dateiattribute speichern.
- **File Area:** Der Hauptbereich der Partition, in dem Dateien und Verzeichnisse gespeichert sind.

Hinweis: Beim Formatieren einer Partition können die vorherigen Daten noch wiederherstellbar sein, da nicht alle Daten vollständig entfernt werden. Es wird empfohlen, eine sichere Löschung auf einem Laufwerk durchzuführen, das wiederverwendet wird. Bei der sicheren Löschung werden die Daten mehrmals auf das gesamte Laufwerk geschrieben, um sicherzustellen, dass keine Daten mehr vorhanden sind.



Alternate Data Streams

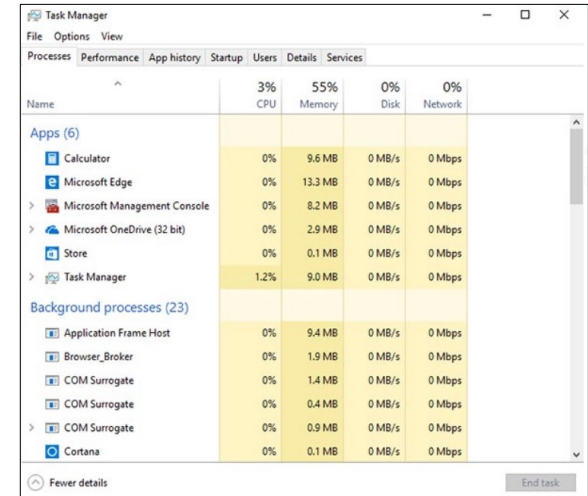
- NTFS speichert Dateien als eine Reihe von Attributen, wie z. B. den Namen der Datei oder einen Zeitstempel.
- Die Daten, die die Datei enthält, werden in dem Attribut **\$DATA** gespeichert und als **Data Stream** bezeichnet.
- Bei Verwendung von NTFS können **Alternate Data Streams** (ADS) mit der Datei verbunden werden.
- Ein Angreifer könnte bösartigen Code innerhalb eines ADS speichern, der dann von einer anderen Datei aus aufgerufen werden kann.
- Im NTFS-Dateisystem wird eine Datei mit einem ADS nach dem Dateinamen und einem Doppelpunkt gekennzeichnet, z. B. Testdatei.txt:ADS. Dieser Dateiname zeigt an, dass ein ADS namens ADS mit der Datei namens Testfile.txt verbunden ist.

```
C:\ADS> echo "Alternate Data Here" > Testfile.txt:ADS
C:\ADS> dir
Volume in drive C is Windows
Volume Serial Number is A606-CB1B
Directory of C:\ADS
2020-04-28  04:01 PM  <DIR>          .
2020-04-28  04:01 PM  <DIR>          ..
2020-04-28  04:01 PM                                0 Testfile.txt
                                           1 File(s)          0 bytes
                                           2 Dir(s)  43,509,571,584 bytes free
C:\ADS> more < Testfile.txt:ADS
"Alternate Data Here"
C:\ADS> dir /r
Volume in drive C is Windows
Volume Serial Number is A606-CB1B
Directory of C:\ADS
2020-04-28  04:01 PM  <DIR>          .
2020-04-28  04:01 PM  <DIR>          ..
2020-04-28  04:01 PM                                0 Testfile.txt
                                           24 Testfile.txt:ADS:$DATA
                                           1 File(s)          0 bytes
                                           2 Dir(s)  43,509,624,832 bytes free
C:\ADS>
```



Processes, Threads und Services

- Eine Windows-Anwendung setzt sich aus Prozessen zusammen. Ein Prozess ist ein beliebiges Programm, das gerade ausgeführt wird.
- Jeder Prozess, der ausgeführt wird, besteht aus mindestens einem Thread. Ein Thread ist ein Teil des Prozesses, der ausgeführt werden kann.
- Die Registerkarte "Prozesse" des Task-Managers ist in der Abbildung dargestellt.
- Alle einem Prozess zugeordneten Threads befinden sich im gleichen Adressraum, d. h. diese Threads dürfen nicht auf den Adressraum eines anderen Prozesses zugreifen. Dies verhindert eine Beeinträchtigung anderer Prozesse.

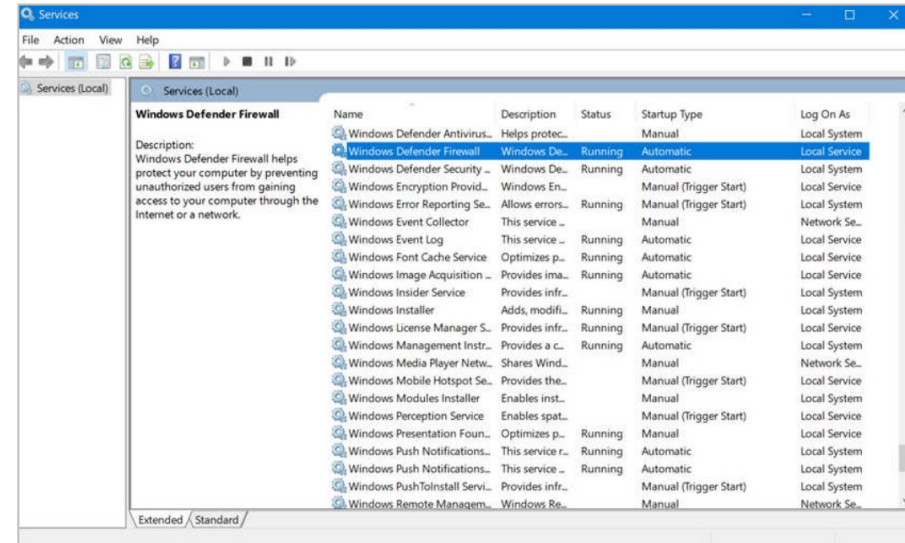


Name	3% CPU	55% Memory	0% Disk	0% Network
Apps (6)				
Calculator	0%	9.6 MB	0 MB/s	0 Mbps
Microsoft Edge	0%	13.3 MB	0 MB/s	0 Mbps
Microsoft Management Console	0%	8.2 MB	0 MB/s	0 Mbps
Microsoft OneDrive (32 bit)	0%	2.9 MB	0 MB/s	0 Mbps
Store	0%	0.1 MB	0 MB/s	0 Mbps
Task Manager	1.2%	9.0 MB	0 MB/s	0 Mbps
Background processes (23)				
Application Frame Host	0%	9.4 MB	0 MB/s	0 Mbps
Browser_Broker	0%	1.9 MB	0 MB/s	0 Mbps
COM Surrogate	0%	1.4 MB	0 MB/s	0 Mbps
COM Surrogate	0%	0.4 MB	0 MB/s	0 Mbps
COM Surrogate	0%	0.9 MB	0 MB/s	0 Mbps
Cortana	0%	0.1 MB	0 MB/s	0 Mbps



Processes, Threads und Services

- Einige der Prozesse, die Windows ausführt, sind Dienste oder Services. Dies sind Programme, die im Hintergrund laufen, um das Betriebssystem und die Anwendungen zu unterstützen.
- Dienste oder Services stellen langlaufende Funktionen bereit, wie z. B. Wireless oder den Zugriff auf einen FTP-Server.
- Das Applet der Systemsteuerung für Windows-Dienste ist in der Abbildung zu sehen.
- Man sollte vorsichtig sein, wenn man die Einstellungen dieser Services manipuliert. Das Herunterfahren eines Dienstes kann sich nachteilig auf Anwendungen oder andere Dienste auswirken.





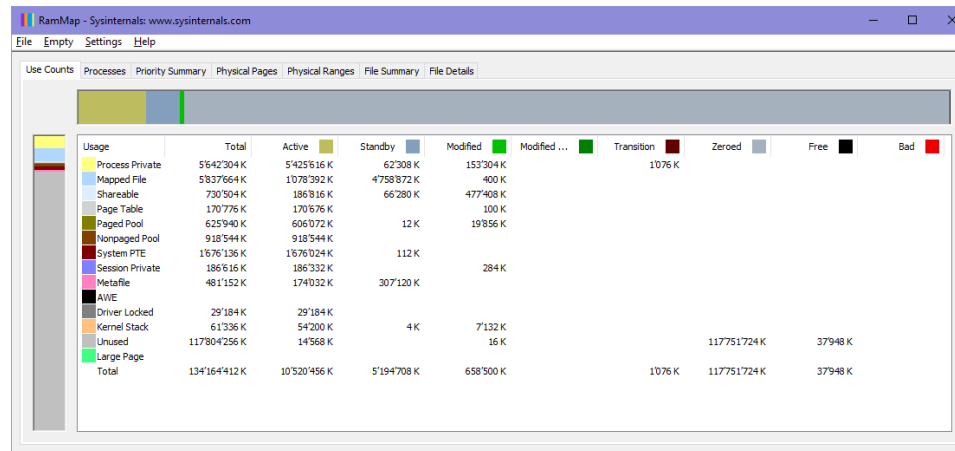
Memory Allocation and Handles

- Der virtuelle Adressraum für einen Prozess ist die Menge der virtuellen Adressen, die der Prozess verwenden kann.
- Die virtuelle Adresse ist nicht der tatsächliche physische Ort im Speicher, sondern ein Eintrag in einer Seitentabelle, die zur Übersetzung der virtuellen Adresse in die physische Adresse verwendet wird.
- Jeder Prozess in einem 32-Bit-Windows-Computer unterstützt einen virtuellen Adressraum, der die Adressierung von bis zu 4 Gigabyte ermöglicht.
- Jeder Prozess in einem 64-Bit-Windows-Computer unterstützt einen virtuellen Adressraum von 8 Terabyte.
- Jeder Userspace-Prozess läuft in einem privaten Adressraum, getrennt von anderen Userspace-Prozessen.
- Wenn der Userspace-Prozess auf Kernel-Ressourcen zugreifen muss, muss er ein Prozesshandle verwenden.
- Da der Userspace-Prozess nicht direkt auf diese Kernel-Ressourcen zugreifen darf, bietet das Prozesshandle den vom Userspace-Prozess benötigten Zugriff, ohne dass eine direkte Verbindung zu diesem besteht.



Memory Allocation and Handles

- Ein leistungsfähiges Werkzeug zum Anzeigen der Speicherzuweisung ist RamMap, das in der Abbildung dargestellt ist.
- **RamMap** ist Teil der Windows Sysinternals Suite von Tools. Diese kann von Microsoft heruntergeladen werden. (<https://live.sysinternals.com/>)
- **RamMap** liefert Informationen darüber, wie Windows dem Kernel, den Prozessen, Treibern und Anwendungen Systemspeicher zugewiesen hat.

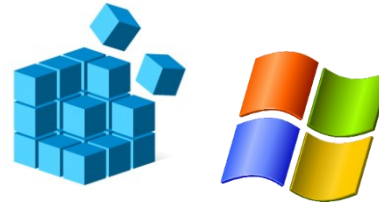




Die Windows Registry

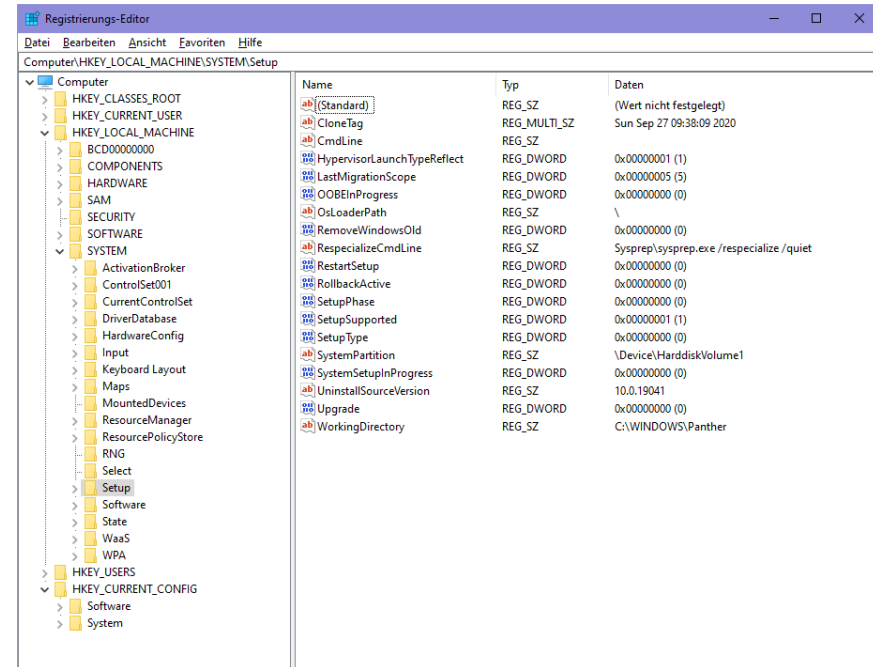
- Windows speichert alle Informationen über Hardware, Anwendungen, Benutzer und Systemeinstellungen in einer grossen Datenbank, der sogenannten Registry.
- Die Registrierung ist eine hierarchische Datenbank, bei der die oberste Ebene als **Hive** bezeichnet wird, darunter gibt es Schlüssel, gefolgt von Unterschlüsseln.
- Werte speichern Daten und werden in den Schlüsseln und Unterschlüsseln gespeichert. Ein Registry-Schlüssel kann bis zu 512 Ebenen tief sein.
- In der folgenden Tabelle sind die fünf Hives der Windows-Registrierung aufgeführt:

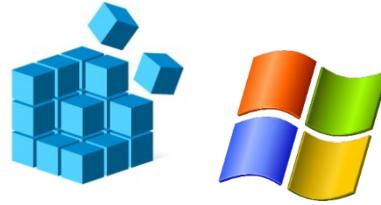
Registry Hive	Description
HKEY_CURRENT_USER (HKCU)	Holds information concerning the currently logged in user.
HKEY_USERS (HKU)	Holds information concerning all the user accounts on the host.
HKEY_CLASSES_ROOT (HKCR)	Holds information about object linking and embedding (OLE) registrations. It allows users to embed objects from other applications into a single document.
HKEY_LOCAL_MACHINE (HKLM)	Holds system-related information.
HKEY_CURRENT_CONFIG (HKCC)	Holds information about the current hardware profile.



Die Windows Registry

- Neue Hives können nicht erstellt werden. Die Registrierungsschlüssel und -werte in den Hives können von einem Konto mit administrativen Rechten erstellt, geändert oder gelöscht werden.
- Wie in der Abbildung dargestellt, wird das Tool **regedit.exe** zum Ändern der Registrierung verwendet.
- Man sollte vorsichtig sein bei der Verwendung dieses Tools. Geringfügige Änderungen an der Registry können massive oder sogar katastrophale Auswirkungen haben.





Die Windows Registry

- Die Navigation in der Registry ist derer des Windows Datei-Explorer sehr ähnlich.
- Man verwendet den linken Bereich, um in den Hives und der darunter liegenden Struktur zu navigieren, und verwendet den rechten Bereich, um den Inhalt des markierten Elements im linken Bereich zu sehen.
- Der Pfad wird am unteren Rand des Fensters als Referenz angezeigt.
- Registry-Schlüssel können entweder einen Unterschlüssel oder einen Wert enthalten. Die verschiedenen Werte, die Schlüssel enthalten können, sind wie folgt:
 - **REG_BINARY**: Zahlen oder boolesche Werte
 - **REG_DWORD**: Zahlen grösser als 32 Bit oder Rohdaten
 - **REG_SZ**: Zeichenkettenwerte
- Die Registrierung enthält auch die Aktivitäten, die ein Benutzer während der normalen täglichen Computernutzung durchführt.
- Dazu gehört die Historie der Hardwaregeräte, inklusive aller Geräte, die an den Computer angeschlossen wurden, sowie Name, Hersteller und Seriennummer.



Linux

- Durch die Überwachung von Linux-Protokolldateien erhält ein Administrator ein klares Bild von der Leistung des Computers, dem Sicherheitsstatus und allen zugrunde liegenden Problemen.
- Unter Linux können Protokolldateien in folgende Kategorien eingeteilt werden:
 - Application logs
 - Event logs
 - Service logs
 - System logs
- Einige Protokolle enthalten Informationen über ***Daemons***, die in Linux ausgeführt werden. Ein Daemon ist ein Hintergrundprozess, der ohne Benutzerinteraktion ausgeführt wird.



Linux

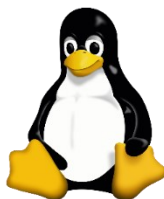
In den folgenden Tabellen sind einige gängige Linux-Protokolldateien, ihr Speicherort und ihre Funktionen/Bedeutung aufgeführt:

Linux Log File	Description
/var/log/messages	• This directory contains generic computer activity logs. • It is mainly used to store informational and non-critical system messages.
/var/log/auth.log	• This file stores all authentication-related events in Debian and Ubuntu computers. • Anything involving the user authorization mechanism can be found in this file.
/var/log/secure	• This directory is used by RedHat and CentOS computers. • It also tracks sudo logins, SSH logins, and other errors logged by SSSD.
/var/log/boot.log	• This file stores boot-related information and messages logged during the computer startup process.



Linux

Linux Log File	Description
/var/log/dmesg	• This directory contains kernel ring buffer messages. • Information related to hardware devices and their drivers is recorded here. • It is very important because, due to their low-level nature, logging systems such as syslog are not running when these events take place and are unavailable to the administrator in real-time.
/var/log/kern.log	• This file contains information logged by the kernel.
/var/log/cron	• Cron is a service used to schedule automated tasks in Linux and this directory stores its events. • Whenever a scheduled task (or cron job) runs, all its relevant information including execution status and error messages are stored here.
/var/log/mysqld.log or /var/log/mysql.log	• This is the MySQL log file. • All debug, failure and success messages related to the mysqld process and mysqld_safe daemon are logged here.



Linux

- Die Befehlsausgabe zeigt einen Teil der Protokolldatei:
/var/log/messages.
- Jede Zeile steht für ein protokolliertes Ereignis.
- Die Zeitstempel am Anfang der Zeilen markieren den Zeitpunkt, an dem das Ereignis stattgefunden hat.

```
[analyst@secOps ~]$ sudo cat /var/log/messages
Mar 20 15:28:45 secOps kernel: Linux version 4.15.10-1-ARCH (builduser@heftig-18961) (gcc version 7.3.1
20180312 (GCC)) #1 SMP PREEMPT Thu Mar 15 12:24:34 UTC 2018
Mar 20 15:28:45 secOps kernel: Command line: BOOT_IMAGE=/boot/vmlinuz-linux root=UUID=07c6b457-3f39-
4ddf-bfd8-c169e8a877b2 rw quiet
Mar 20 15:28:45 secOps kernel: KERNEL supported cpus:
Mar 20 15:28:45 secOps kernel: Intel GenuineIntel
Mar 20 15:28:45 secOps kernel: AMD AuthenticAMD
Mar 20 15:28:45 secOps kernel: Centaur CentaurHauls
Mar 20 15:28:45 secOps kernel: x86/fpu: Supporting XSAVE feature 0x001: 'x87 floating point registers'
Mar 20 15:28:45 secOps kernel: x86/fpu: Supporting XSAVE feature 0x002: 'SSE registers'
Mar 20 15:28:45 secOps kernel: x86/fpu: Supporting XSAVE feature 0x004: 'AVX registers'
Mar 20 15:28:45 secOps kernel: x86/fpu: xstate_offset[2]: 576, xstate_sizes[2]: 256
Mar 20 15:28:45 secOps kernel: x86/fpu: Enabled xstate features 0x7, context size is 832 bytes, using
'standard' format.
Mar 20 15:28:45 secOps kernel: e820: BIOS-provided physical RAM map:
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x0000000000000000-0x000000000009fbff] usable
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x000000000009fc00-0x000000000009ffff] reserved
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x00000000000a0000-0x000000000000ffff] reserved
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x00000000000100000-0x00000000003ffff] usable
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x000000003ffff000-0x000000003ffff] ACPI data
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x00000000fec00000-0x00000000fec00fff] reserved
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x00000000fee00000-0x00000000fee00fff] reserved
Mar 20 15:28:45 secOps kernel: BIOS-e820: [mem 0x00000000ffffc000-0x00000000ffffffffff] reserved
Mar 20 15:28:45 secOps kernel: NX (Execute Disable) protection: active
Mar 20 15:28:45 secOps kernel: random: fast init done
Mar 20 15:28:45 secOps kernel: SMBIOS 2.5 present.
Mar 20 15:28:45 secOps kernel: DMI: innotek GmbH VirtualBox/VirtualBox, BIOS VirtualBox 12/01/2006
Mar 20 15:28:45 secOps kernel: Hypervisor detected: KVM
Mar 20 15:28:45 secOps kernel: e820: last_pfn = 0x3ffff max_arch_pfn = 0x40000000
Mar 20 15:28:45 secOps kernel: MTRR: Disabled
Mar 20 15:28:45 secOps kernel: x86/PAT: MTRRs disabled, skipping PAT initialization too.
Mar 20 15:28:45 secOps kernel: CPU MTRRs all blank - virtualized system.
```

Networking – *nslookup*

- Das Domain Name System (DNS) sollte ebenfalls getestet werden, da es für das Auffinden der IP-Adresse von Hosts unerlässlich ist, indem es diese aus einem Namen, z. B. einer URL, übersetzt.
- Man verwendet dazu (sowohl unter Windows als auch Linux) den Befehl: ***nslookup***
- Durch verschiedene Optionen lassen sich noch weiter Informationen über die untersuchte Domain rausfinden (DNS-Server, Mail-Server, etc.)

```
Eingabeaufforderung - nslookup
Microsoft Windows [Version 10.0.19042.804]
(c) 2020 Microsoft Corporation. Alle Rechte vorbehalten.

C:\Users\pisoft>nslookup
Standardserver: internetbox.home
Address: 192.168.1.1

> server 9.9.9.9
Standardserver: dns9.quad9.net
Address: 9.9.9.9

> www.cisco.com
Server: dns9.quad9.net
Address: 9.9.9.9

Nicht autorisierende Antwort:
Name:      e2867.dsca.akamaiedge.net
Addresses: 2a02:26f0:3000:289::b33
           2a02:26f0:3000:291::b33
           23.208.34.31
Aliases:   www.cisco.com
           www.cisco.com.akadns.net
           wwwds.cisco.com.edgekey.net
           wwwds.cisco.com.edgekey.net.globalredir.akadns.net

>
```

```
Eingabeaufforderung - nslookup
Microsoft Windows [Version 10.0.19042.804]
(c) 2020 Microsoft Corporation. Alle Rechte vorbehalten.

C:\Users\pisoft>nslookup
Standardserver: internetbox.home
Address: 192.168.1.1

> server 9.9.9.9
Standardserver: dns9.quad9.net
Address: 9.9.9.9

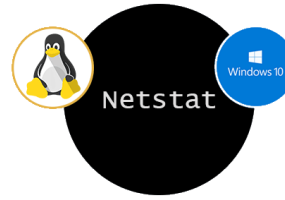
> set type=all
> cisco.com
Server: dns9.quad9.net
Address: 9.9.9.9

Nicht autorisierende Antwort:
cisco.com      nameserver = ns1.cisco.com
cisco.com      nameserver = ns3.cisco.com
cisco.com      nameserver = ns2.cisco.com

> set type=mx
> cisco.com
Server: dns9.quad9.net
Address: 9.9.9.9

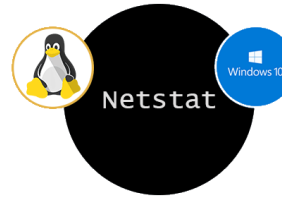
Nicht autorisierende Antwort:
cisco.com      MX preference = 30, mail exchanger = aer-mx-01.cisco.com
cisco.com      MX preference = 20, mail exchanger = rcdn-mx-01.cisco.com
cisco.com      MX preference = 10, mail exchanger = alln-mx-01.cisco.com

>
```



Networking – *netstat*

- Mit ***netstat*** (gleich für Windows und Linux) kann man sich Details zu aktiven Netzwerkverbindungen von und zu dem Host anzeigen lassen.
- Der Befehl wird verwendet, um nach eingehenden oder ausgehenden Verbindungen zu suchen, die nicht autorisiert sind.
- Der Befehl ***netstat*** zeigt alle aktiven TCP- (oder UDP-) Verbindungen an.
- Durch die Untersuchung dieser Verbindungen ist es möglich, die Programme zu ermitteln, die auf nicht autorisierte Verbindungen lauschen.
- Wenn der Verdacht besteht, dass es sich bei einem Programm um Malware handelt, kann der Prozess mit dem Task-Manager beendet und eine Software zum Entfernen von Malware verwendet werden, um den Computer zu reinigen.
- Um diesen Vorgang zu erleichtern, können die Verbindungen mit den laufenden Prozessen verknüpft werden, welche im Task-Manager ersichtlich ist.



Networking – *netstat*

- Man öffnet dazu eine Eingabeaufforderung mit administrativen Rechten und geben gibt den Befehl ***netstat -abno*** ein.
- Durch die Untersuchung der aktiven Verbindungen sollte ein Analyst feststellen können, ob es verdächtige Programme gibt, die auf dem Host auf eingehende Verbindungen warten.
- Möglicherweise ist mehr als ein Prozess mit demselben Namen aufgeführt. Wenn dies der Fall ist, verwendet man die eindeutige PID (Process-ID), um den richtigen Prozess zu finden.
- Um die PIDs für die Prozesse im Task-Manager anzuzeigen, öffnet man den Task-Manager, und klickt mit der rechten Maustaste auf die Tabellenüberschrift und wählt die entsprechende PID.

```
Administrator: Eingabeaufforderung
C:\WINDOWS\system32>netstat

Aktive Verbindungen

Proto Lokale Adresse Remoteadresse Status
TCP 127.0.0.1:49671 Dunkelsteus:49672 HERGESTELLT
TCP 127.0.0.1:49672 Dunkelsteus:49671 HERGESTELLT
TCP 127.0.0.1:49673 Dunkelsteus:49685 HERGESTELLT
TCP 127.0.0.1:49673 Dunkelsteus:49691 HERGESTELLT
TCP 127.0.0.1:49685 Dunkelsteus:49673 HERGESTELLT
TCP 127.0.0.1:49691 Dunkelsteus:49673 HERGESTELLT
TCP 127.0.0.1:49698 Dunkelsteus:49699 HERGESTELLT
TCP 127.0.0.1:49699 Dunkelsteus:49698 HERGESTELLT
TCP 192.168.0.63:1824 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1825 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1826 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1827 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1828 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1829 Internetbox:domain HERGESTELLT
TCP 192.168.0.63:1375 172.68.253.13:https HERGESTELLT
```

```
Administrator: Eingabeaufforderung
C:\WINDOWS\system32>netstat -abno

Aktive Verbindungen

Proto Lokale Adresse Remoteadresse Status PID
TCP 0.0.0.0:7 0.0.0.0:0 ABHÖREN 6112
[tcpsvcs.exe]
TCP 0.0.0.0:9 0.0.0.0:0 ABHÖREN 6112
[tcpsvcs.exe]
TCP 0.0.0.0:13 0.0.0.0:0 ABHÖREN 6112
[tcpsvcs.exe]
TCP 0.0.0.0:17 0.0.0.0:0 ABHÖREN 6112
[tcpsvcs.exe]
TCP 0.0.0.0:19 0.0.0.0:0 ABHÖREN 6112
[tcpsvcs.exe]
TCP 0.0.0.0:135 0.0.0.0:0 ABHÖREN 1980
Rpcss
[svchost.exe]
TCP 0.0.0.0:443 0.0.0.0:0 ABHÖREN 9052
[vmware-hostd.exe]
TCP 0.0.0.0:445 0.0.0.0:0 ABHÖREN 4
Es konnten keine Besitzerinformationen abgerufen werden.
TCP 0.0.0.0:902 0.0.0.0:0 ABHÖREN 6072
[vmware-authd.exe]
TCP 0.0.0.0:912 0.0.0.0:0 ABHÖREN 6072
[vmware-authd.exe]
TCP 0.0.0.0:1462 0.0.0.0:0 ABHÖREN 4
Es konnten keine Besitzerinformationen abgerufen werden.
TCP 0.0.0.0:1467 0.0.0.0:0 ABHÖREN 4
```


Datenquellen – syslog

- Syslog umfasst Spezifikationen für **Nachrichtenformate** (Syntax), ist eine Client/Server-Anwendungsstruktur und ist ein **Netzwerkprotokoll**.
- Viele verschiedene Arten von Netzwerkgeräten können so konfiguriert werden, dass sie den Syslog-Standard verwenden, um Ereignisse auf zentralen Syslog-Servern zu protokollieren.



SYSLOG Beispielmessages

R1#

*Feb 14 09:38:48.132: %SYS-5-CONFIG_I: Configured from console by console

R1#

*Feb 14 09:40:09.325: %LINK-3-UPDOWN: Interface GigabitEthernet0/1, changed state to up

*Feb 14 09:40:10.326: %LINEPROTO-5-UPDOWN: Line protocol on Interface
GigabitEthernet0/1, changed state to up

R1#

*Feb 14 09:40:10.326: %LINEPROTO-5-UPDOWN: Line protocol on Interface
GigabitEthernet0/1, changed state to up

- **timestamp**: Feb 14 0:40:10.326
- **facility**: %LINEPROTO
- **severity level**: 5
- **mnemonic**: UPDOWN
- **description**: Line protocol on Interface GigabitEthernet0/1, changed state to up

Syslog – facility

- Facility-Codes zwischen 16 und 23 (local0-local7) sind nicht mit einem Schlüsselwort oder Namen belegt.
- Ihnen können je nach Verwendungskontext **unterschiedliche Bedeutungen zugewiesen** werden.
- verschiedene Betriebssysteme verwenden sowohl Facility 9 als auch 15 für Clock-Messages verwenden.
- In RFC 3164 definiert

(btw.: rsyslog ist eine open-source Implementierung für Unix)

Quelle: techtarget.com

Syslog Facility Codes

FACILITY CODE	BESCHREIBUNG
0	Kernel
1	Benutzer
2	Mail
3	System-Daemons
4	Sicherheits-/Autorisierungsmeldungen
5	Interne Syslog-Daemon-Meldungen
6	Zeilendrucker-Subsystem
7	Netzwerk-Nachrichten-Subsystem
8	UUCP-Subsystem
9	Uhr-Daemon
10	Sicherheits-/Auth-Meldungen
11	FTP-Daemon
12	NTP-Subsystem
13	Log-Audit
14	Log-Alarm
15	Zeitplan-Daemon
16 bis 23	Lokal verwendete Facilities, local0 bis local7

Syslog –severity

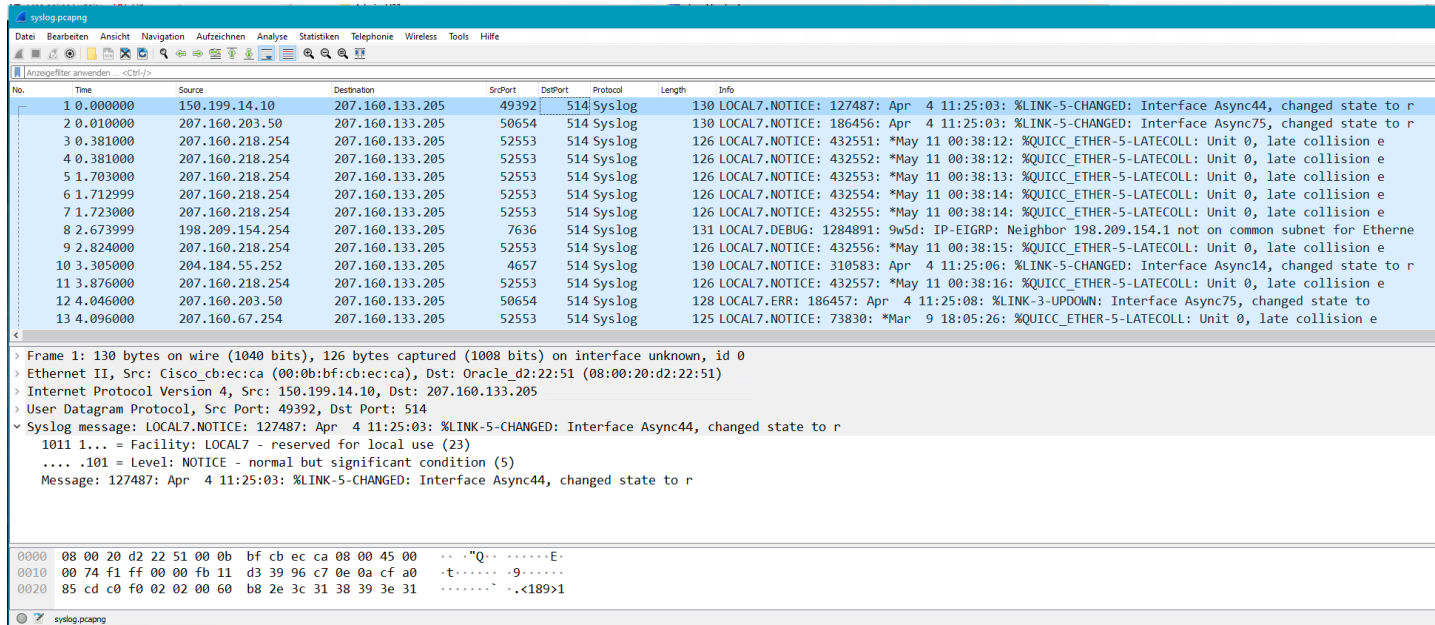
- Die Severity Levels geben Auskunft über die Dringlichkeit und Kritikalität von Systemmeldungen.
- Sie sind ein zentraler Bestandteil des Syslog-Protokolls und helfen Administratoren, Ereignisse nach ihrer Wichtigkeit zu **priorisieren**.

Value	Severity
0	Emergency: system is unusable
1	Alert: action must be taken immediately
2	Critical: critical conditions that should be corrected immediately and indicates failure in a system
3	Error: a failure that is not urgent, should be resolved within a given time
4	Warning: an error does not presently exist; but, an error will occur in the future if the condition is not addressed
5	Notice: an event that is not an error, but that is considered unusual. Does not require immediate action.
6	Informational: messages issued regarding normal operation
7	Debug: messages of interest to developers

```
08:01:13: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to up
08:01:23: %DUAL-5-NBRCHANGE: EIGRP-IPv4:(1) 1: Neighbor 10.1.1.1 (Vlan1) is up: new
adjacency
08:02:31: %LINK-3-UPDOWN: Interface FastEthernet0/5, changed state to up
08:18:20: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to down
08:18:22: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to up
08:18:24: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to down
08:18:24: %ILPOWER-5-IFMIB: Interface FastEthernet0/5, power state changed to down
08:18:26: %LINK-3-UPDOWN: Interface FastEthernet0/5, changed state to down
08:19:49: %ILPOWER-7-DIAG: Interface FastEthernet0/5, power state changed to down
08:19:53: %LINK-3-UPDOWN: Interface FastEthernet0/5, changed state to down
08:19:53: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to up
08:27:42: %SYS-5-CONFIG: System configuration changed
08:29:32: %ILPOWER-7-DIAG: Interface FastEthernet0/5, power state changed to down
08:29:36: %LINK-3-UPDOWN: Interface FastEthernet0/5, changed state to down
08:29:36: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to up
08:31:19: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to down
08:31:21: %LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/5, changed state
to up
```

Kiwi Syslog Service Manager					
File Edit View Manage Help					
Display 00 (Default)					
I	Date	Time	Priority	Hostname	Message
!	09-06-2012	16:44:54	System4.Warning	10.100.1.192	Test user connected to website http://215.147.16.31/index.html
!	09-06-2012	16:44:53	Local5.Info	10.100.1.192	Test user connected to website http://195.127.200.148/index.html
!	09-06-2012	16:44:52	System5.Warning	10.100.1.192	Test user connected to website http://222.169.198.63/index.html
!	09-06-2012	16:44:51	Local5.Alert	10.100.1.192	Test user connected to website http://194.25.191.172/index.html
!	09-06-2012	16:44:50	UUCP.Alert	10.100.1.192	Test user connected to website http://220.245.188.16/index.html
!	09-06-2012	16:44:49	Auth.Critical	10.100.1.192	Test user connected to website http://220.234.172.242/index.html
!	09-06-2012	16:44:48	Local2.Warning	10.100.1.192	Test user connected to website http://203.44.165.1/index.html
!	09-06-2012	16:44:47	Auth.Error	10.100.1.192	Test user connected to website http://201.87.195.218/index.html
!	09-06-2012	16:44:45	Local5.Error	10.100.1.192	Test user connected to website http://200.119.197.212/index.html
!	09-06-2012	16:44:44	Local0.Notice	10.100.1.192	Test user connected to website http://204.135.209.16/index.html
!	09-06-2012	16:44:43	Kernel.Critical	10.100.1.192	Test user connected to website http://218.120.20.60/index.html
!	09-06-2012	16:44:42	Local3.Error	10.100.1.192	Test user connected to website http://204.138.2.38/index.html
!	09-06-2012	16:44:41	Syslog.Info	10.100.1.192	Test user connected to website http://210.112.153.158/index.html
!	09-06-2012	16:44:40	Local7.Debug	10.100.1.192	Test user connected to website http://204.160.214.145/index.html
!	09-06-2012	16:44:39	Mail.Error	10.100.1.192	Test user connected to website http://196.182.33.60/index.html
!	09-06-2012	16:44:38	UUCP.Alert	10.100.1.192	Test user connected to website http://209.214.132.220/index.html
!	09-06-2012	16:44:37	Local2.Warning	10.100.1.192	Test user connected to website http://218.112.12.113/index.html
!	09-06-2012	16:44:36	System5.Notice	10.100.1.192	Test user connected to website http://207.212.93.24/index.html
!	09-06-2012	16:44:35	UUCP.Critical	10.100.1.192	Test user connected to website http://212.127.130.92/index.html
!	09-06-2012	16:44:34	Local2.Alert	10.100.1.192	Test user connected to website http://222.245.162.138/index.html
!	09-06-2012	16:44:33	User.Notice	10.100.1.192	Test user connected to website http://214.185.211.162/index.html
!	09-06-2012	16:44:32	User.Critical	10.100.1.192	Test user connected to website http://213.153.135.176/index.html
!	09-06-2012	16:44:31	System0.Critical	10.100.1.192	Test user connected to website http://211.94.23.143/index.html
!	09-06-2012	16:44:30	Local3.Info	10.100.1.192	Test user connected to website http://208.183.114.103/index.html
!	09-06-2012	16:44:29	Kernel.Notice	10.100.1.192	Test user connected to website http://200.195.17.96/index.html

Syslog – Transport



The screenshot displays the syslog-ng application window. The top menu bar includes 'Datei', 'Bearbeiten', 'Ansicht', 'Navigation', 'Aufzeichnen', 'Analyse', 'Statistiken', 'Telephonie', 'Wireless', 'Tools', and 'Hilfe'. Below the menu is a toolbar with various icons. The main window is divided into two panes. The top pane shows a table of captured messages with columns: No., Time, Source, Destination, SrcPort, DestPort, Protocol, Length, and Info. The bottom pane shows the details of the selected message (No. 1), including the frame size, Ethernet II header, Internet Protocol Version 4 header, User Datagram Protocol header, and the Syslog message content.

No.	Time	Source	Destination	SrcPort	DestPort	Protocol	Length	Info
1	0.000000	150.199.14.10	207.160.133.205	49392	514	Syslog	130	LOCAL7.NOTICE: 127487: Apr 4 11:25:03: %LINK-5-CHANGED: Interface Async44, changed state to r
2	0.010000	207.160.203.50	207.160.133.205	50654	514	Syslog	130	LOCAL7.NOTICE: 186456: Apr 4 11:25:03: %LINK-5-CHANGED: Interface Async75, changed state to r
3	0.381000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432551: *May 11 00:38:12: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
4	0.381000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432552: *May 11 00:38:12: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
5	1.703000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432553: *May 11 00:38:13: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
6	1.712999	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432554: *May 11 00:38:14: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
7	1.723000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432555: *May 11 00:38:14: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
8	2.673999	198.209.154.254	207.160.133.205	7636	514	Syslog	131	LOCAL7.DEBUG: 1284891: 9w5d: IP-EIGRP: Neighbor 198.209.154.1 not on common subnet for Etherne
9	2.824000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432556: *May 11 00:38:15: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
10	3.305000	204.184.55.252	207.160.133.205	4657	514	Syslog	130	LOCAL7.NOTICE: 310583: Apr 4 11:25:06: %LINK-5-CHANGED: Interface Async14, changed state to r
11	3.876000	207.160.218.254	207.160.133.205	52553	514	Syslog	126	LOCAL7.NOTICE: 432557: *May 11 00:38:16: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e
12	4.046000	207.160.203.50	207.160.133.205	50654	514	Syslog	128	LOCAL7.ERR: 186457: Apr 4 11:25:08: %LINK-3-UPDOWN: Interface Async75, changed state to
13	4.096000	207.160.67.254	207.160.133.205	52553	514	Syslog	125	LOCAL7.NOTICE: 73830: *Mar 9 18:05:26: %QUICC_ETHER-5-LATECOLL: Unit 0, late collision e

> Frame 1: 130 bytes on wire (1040 bits), 126 bytes captured (1008 bits) on interface unknown, id 0
> Ethernet II, Src: Cisco_cb:ec:ca (00:0b:bf:cb:ec:ca), Dst: Oracle_d2:22:51 (08:00:20:d2:22:51)
> Internet Protocol Version 4, Src: 150.199.14.10, Dst: 207.160.133.205
> User Datagram Protocol, Src Port: 49392, Dst Port: 514
v Syslog message: LOCAL7.NOTICE: 127487: Apr 4 11:25:03: %LINK-5-CHANGED: Interface Async44, changed state to r
1011 1... = Facility: LOCAL7 - reserved for local use (23)
....101 = Level: NOTICE - normal but significant condition (5)
Message: 127487: Apr 4 11:25:03: %LINK-5-CHANGED: Interface Async44, changed state to r

0000 08 00 20 d2 22 51 00 0b bf cb ec ca 08 00 45 00 .."Q.. ..E:
0010 00 74 f1 ff 00 00 fb 11 d3 39 96 c7 0e 0a cf a0 -t.....-9.....
0020 85 cd c0 f0 02 02 00 60 b8 2e 3c 31 38 39 3e 31<189>1

Arbeitet mit **UDP** auf den Zielport: **514**
Gewisse Standards (PCI-DSS, HIPAA) verlangen einen sicheren Transport der syslog-Messages. In diesem Fall verwendet man **TCP** auf dem Port **6514**

Weiterentwicklung: SYSLOG-NG

- Eine Weiterentwicklung von Syslog mit dem Ziel, die bekannten Schwachstellen zu beheben.
- Es erweitert das ursprüngliche syslogd-Modell um inhaltsbasierte Filterung, umfangreiche Filterfunktionen, flexible Konfigurationsoptionen und fügt wichtige Funktionen zu syslog hinzu, wie z.B. die Verwendung von **TCP für den Transport**.
- Durch eine Installation von **syslog-ng** kann ein homogenes Logging-System auf allen beteiligten Rechnern ermöglicht werden.
- Diese Eigenschaften sind ein grosser Anreiz und Grund für die Verbreitung des Programms.

syslog-ng

SYSLOG-NG



- syslog-ng wird entwickelt von der Firma Balabit (<https://www.balabit.com/>) und wurde kürzlich von der Firma OneIdentity übernommen (<https://www.oneidentity.com/>)
- syslog-ng ist aber prinzipiell "free and open-source" Software wobei durch die Firma Varianten mit erweiterter Funktionalität kostenpflichtig abgegeben werden – als kommerzielle Produkte.



Server / Service Logs

- Server-Logs sind eine wesentliche Datenquelle für die Überwachung der Netzwerksicherheit.
- Besonders wichtig sind DNS-, Proxy-, Server-Logs, die z.B. alle DNS-Anfragen und -Antworten dokumentieren, die im Netzwerk auftreten.
- Zwei wichtige Log-Dateien sind das Apache-Webserver-Access-Log und Microsoft Internet Information Server (IIS)-Access-Log.

```
203.0.113.127 - dsmith [10/Oct/2016:10:26:57 - 0500] "GET /logo_sm.gif HTTP/1.0" 200 2254  
""http://www.example.com/links.html"" "Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:47.0) Gecko/20100101  
Firefox/47.0"
```

```
6/14/2016, 16:22:43, 203.0.113.24, -, W3SVC2, WEB3, 198.51.100.10, 80, GET, /home.htm, -, 200, 0, 15321,  
159, 15, HTTP/1.1, Mozilla/5.0 (compatible; MSIE 9.0; Windows Phone OS 7.5; Trident/5.0; IEMobile/9.0),  
-, http://www.example.com
```

Session- und Transaktionsdaten

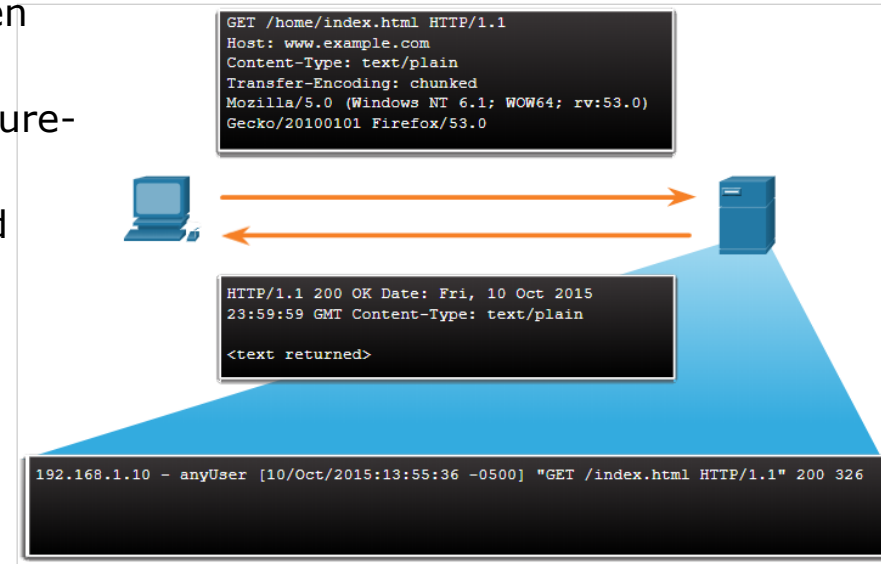
- Zu den Daten über Sessions gehören eine Session-ID, die übertragene Datenmenge nach Quelle und Ziel sowie Informationen über die Dauer der Session.
- Die Abbildung zeigt einen Ausschnitt für drei HTTP-Sitzungen aus einem Zeek**-Verbindungslog.
- Sessiondaten sind eine Aufzeichnung einer Konversation zwischen zwei Netzwerkendpunkten.
- Sie enthalten ein **fünf-Tupel** von **Quell-** und **Ziel-IP-Adressen**, **Quell-** und **Ziel-Port-** Nummern und den **IP-Code** für das verwendete Protokoll.

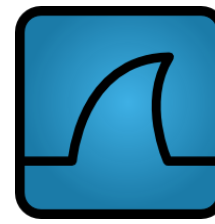
1	2	3	4	5	6	7	8	9	10	11	12	13
ts	uid	id.orig_h	id.orig_p	id.resp_h	id.resp_p	proto	service	duration	orig_bytes	resp_bytes	orig_pkts	resp_pkts
1320279567	CEv1Z54N5gT3PwUlog	192.168.2.76	52034	174.129.249.33	80	tcp	http	0.082899	389	1495	5	4
1320279567	Ci8Ueb3SkSiHwASNIN4	192.168.2.76	52035	184.72.234.3	80	tcp	http	2.56194	905	731	9	8
1320279567	CaTMSv1Sb8HfFunqj	192.168.2.76	52033	184.72.234.3	80	tcp	http	3.345539	1856	1445	15	13

1. **ts**: session start timestamp
2. **uid**: unique session ID
3. **id.orig_h**: IP address of host that originated the session (source address)
4. **id.orig_p**: protocol port for the originating host (source port)
5. **id.resp_h**: IP address of host responding to the originating host (destination address)
6. **id.resp_p**: protocol of responding host (destination port)
7. **proto**: transport layer protocol for session
8. **service**: application layer protocol
9. **duration**: duration of the session
10. **orig_bytes**: bytes from originating host
11. **resp_bytes**: bytes from responding host
12. **orig_packets**: packets from the originating host
13. **resp_packets**: packets from responding host

Session- und Transaktionsdaten

- Transaktionsdaten bestehen aus den Nachrichten, die während Netzwerksitzungen ausgetauscht werden.
- Diese Transaktionen können in Packet-Capture-Transkripts eingesehen werden.
- Die Transaktionen, welche die Anfragen und Antworten darstellen, würden in einem Zugriffsprotokoll auf einem Server oder von einem NIDS wie Zeek protokolliert werden.
- Eine Sitzung könnte das Herunterladen von Inhalten von einem Webserver beinhalten, wie in der Abbildung dargestellt.





Full Packet Captures

- Vollständige Paketaufzeichnungen sind die detailliertesten Netzwerkdaten, die im Allgemeinen gesammelt werden.
- Sie enthalten den tatsächlichen Inhalt der Unterhaltungen, wie z. B. den Text von E-Mail-Nachrichten, den HTML-Code in Webseiten und die Dateien, die das Netzwerk betreten oder verlassen.
- Extrahierte Inhalte können aus vollständigen Paketaufzeichnungen wiederhergestellt und auf Malware oder auf Geschäfts- und Sicherheitsrichtlinien verstossendes Benutzerverhalten analysiert werden.
- Die Abbildung hier zeigt die Schnittstelle für die Network Analysis Monitor-Komponente (NAM) des Cisco Prime Infrastructure-Systems, welche vollständige Packet Captures anzeigen kann.

The screenshot shows the Cisco NAM Packet Analyzer interface. At the top, there's a 'Display Filter' section and a 'Filter' input field. Below this is a table of captured packets. The selected packet (No. 38333) is highlighted in green. The details pane on the right shows the packet structure: Ethernet II, Internet Protocol Version 4, Transmission Control Protocol, and Hypertext Transfer Protocol. The packet data is displayed in hexadecimal and ASCII format.

No.	Time	Source	Destination	Protocol	Length	Info
38333	2.691104	1.3.2.178	1.2.0.2	TCP	70	[TCP Dup ACK 34839#1] [TCP ACKed unseen segment] 54735 > http [ACK]
38334	2.691167	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38335	2.691175	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38336	2.691189	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38337	2.691193	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38338	2.691214	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...
38339	2.691221	1.4.0.1	1.1.2.27	HTTP	1504	[TCP Previous segment not captured] Continuation or non-HTTP traffic[Packe...

Frame 1: 1504 bytes on wire (12032 bits), 1500 bytes captured (12000 bits)

Ethernet II, Src: 02:1ac5:01:00:00 (02:1ac5:01:00:00), Dst: 02:1ac5:02:00:00 (02:1ac5:02:00:00)

Internet Protocol Version 4, Src: 1.2.0.2 (1.2.0.2), Dst: 1.3.1.229 (1.3.1.229)

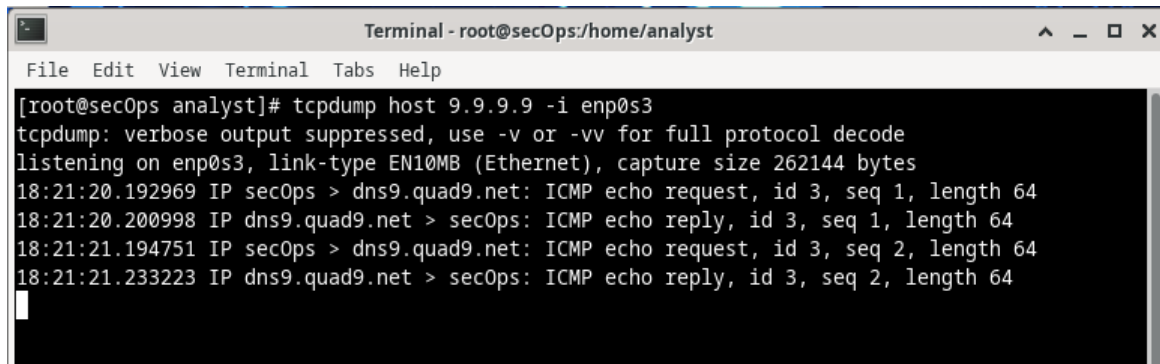
Transmission Control Protocol, Src Port: http (80), Dst Port: 55998 (55998), Seq: 1, Ack: 1, Len: 1438

Hypertext Transfer Protocol

0000 02 1A C5 02 00 00 02 1A C5 01 00 00 08 00 45 00E.
0010 05 DC 87 D5 40 00 20 06 C9 58 01 02 00 02 01 03 ...@..[.....
0020 01 E5 00 50 DA BE CF FD 2D 19 4F DA E7 D9 80 18 ...P.....O.....
0030 1C 48 BE E1 00 00 01 01 08 0A AC 19 04 03 AB C7 .H.....
0040 79 16 37 BE 45 A5 2F 06 30 9C 7E 72 07 50 01 17 y.7.E./0.-r.P..
0050 3B 71 79 A9 68 D0 08 B8 17 58 97 88 42 C7 9E 55 jgy.k....X..h..U
0060 FF 2F 83 02 04 72 00 26 16 89 3C 21 68 B8 04 E0 ./...&...<h...
0070 00 D4 DE 59 AB 69 AA A0 BC 08 C9 61 B8 C4 C8 ...Y.1.....a...
0080 FF 1E 7F 8B 5A DC B3 FB DC 55 93 00 A9 79 83 35 ...Z....U...Y.5

Full Packet Captures – tcpdump/Wireshark

- Das Kommandozeilenwerkzeug *tcpdump* ist ein sehr beliebter Paketanalysator.
- Es kann Paketaufzeichnungen in Echtzeit anzeigen oder Paketaufzeichnungen in eine Datei schreiben.
- Es erfasst detaillierte Protokoll- und Inhaltsdaten von Paketen.
- **Wireshark ist eine GUI**, die auf der tcpdump-Funktionalität aufbaut.
- Die Struktur von *tcpdump*-Captures variiert je nach dem erfassten Protokoll und den angeforderten Feldern.

A screenshot of a terminal window titled "Terminal - root@secOps:/home/analyst". The terminal shows the execution of the command "tcpdump host 9.9.9.9 -i enp0s3". The output indicates that verbose output is suppressed and shows four captured packets: two ICMP echo requests and two ICMP echo replies between 18:21:20 and 18:21:21. The terminal window has a menu bar with "File", "Edit", "View", "Terminal", "Tabs", and "Help".

```
Terminal - root@secOps:/home/analyst
File Edit View Terminal Tabs Help
[root@secOps analyst]# tcpdump host 9.9.9.9 -i enp0s3
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on enp0s3, link-type EN10MB (Ethernet), capture size 262144 bytes
18:21:20.192969 IP secOps > dns9.quad9.net: ICMP echo request, id 3, seq 1, length 64
18:21:20.200998 IP dns9.quad9.net > secOps: ICMP echo reply, id 3, seq 1, length 64
18:21:21.194751 IP secOps > dns9.quad9.net: ICMP echo request, id 3, seq 2, length 64
18:21:21.233223 IP dns9.quad9.net > secOps: ICMP echo reply, id 3, seq 2, length 64
```



"Swiss Army Knife" - Stratoshark

- Stratoshark ist ein Open-Source-Tool zur Analyse von Systemaufrufen und Logdaten, das die Transparenz von Wireshark auf Betriebssystemebene bringt.
- Es bietet folgende Funktionen:
 - **Analyse von Systemcalls und Logs:** Stratoshark untersucht Funktionen wie `read()`, `write()`, `socket()` oder `sendmsg()` und hilft dabei, das Verhalten von Anwendungen auf Betriebssystemebene zu verstehen².
 - **Fehlersuche und Sicherheitsanalyse:** Ideal zur Diagnose von Systemproblemen und zur Reaktion auf Sicherheitsvorfälle.
 - **Wireshark-ähnliche Oberfläche:** Nutzt dieselbe Dissektion- und Filter-Engine wie Wireshark, wodurch die Bedienung vertraut wirkt.
 - **Kompatibilität mit Falco und Sysdig:** Unterstützt dieselben Dateiformate, was einen nahtlosen Wechsel zwischen Tools ermöglicht.
 - **Cloud-Integration:** Mit Plugins wie dem Falco CloudTrail Plugin lassen sich auch AWS-Logs analysieren
- Stratoshark eignet sich besonders für Linux-Systeme, kann aber auch auf Windows und macOS genutzt werden – dort allerdings mit eingeschränkter nativer Capture-Funktion.

Stratoshark



Hochschule Luzern
Computer Science and
Information Technology

The screenshot displays the Stratoshark remote capture interface. The main window shows a list of system events with columns for No., Time, Event name, Dir, Proc Name, PID, TID, FD, FD Name, Container Name, and Arguments. The events are filtered by 'demo.scap' and show a sequence of system calls and file operations. The bottom panel shows the details of the selected event, including the event name, event arguments, process information, process ancestors, container information, user information, and group information. The event details section shows the event name 'System Event 160: 74 bytes', the event arguments, and the process information.

No.	Time	Event name	Dir	Proc Name	PID	TID	FD	FD Name	Container Name	Arguments
274	0.198642114	clock_gettime	>	systemd-journal	125	125			host	
275	0.198643411	clock_gettime	<	systemd-journal	125	125			host	
276	0.198643555	clock_gettime	>	systemd-journal	125	125			host	
277	0.198643522	clock_gettime	<	systemd-journal	125	125			host	
278	0.198646184	clock_gettime	<	systemd-journal	125	125			host	
279	0.198646514	clock_gettime	<	systemd-journal	125	125			host	
280	0.198646362	read	>	systemd-journal	125	125	16		host	fd=16(<-
281	0.198650869	read	<	systemd-journal	125	125	16		host	res=8 dat
282	0.198659806	ffruncate	>	systemd-journal	125	125			host	
283	0.198658461	ffruncate	<	systemd-journal	125	125			host	
284	0.198660725	clock_gettime	>	systemd-journal	125	125			host	
285	0.198660968	clock_gettime	<	systemd-journal	125	125			host	
286	0.198669870	clock_gettime	<	systemd-journal	125	125			host	
287	0.198669293	clock_gettime	<	systemd-journal	125	125			host	
288	0.198669960	gettid	>	systemd-journal	125	125			host	
289	0.198691772	gettid	<	systemd-journal	125	125			host	
290	0.198693171	timerfd_settime	>	systemd-journal	125	125			host	
291	0.198694971	timerfd_settime	<	systemd-journal	125	125			host	
292	0.198696725	epoll_wait	>	systemd-journal	125	125			host	manevents=
293	0.198704165	switch	>	systemd-journal	125	125			host	next=0 pgi
294	0.216753986	switch	>	sysdig	102137	102137			host	next=0 pgi
295	0.247046557	switch	>	sysdig	102137	102137			host	next=0 pgi
296	0.263221354	clock_nanosleep	<	multipathd	184	201			host	addr=5050h
297	0.263231197	futex	<	multipathd	184	201			host	res=1
298	0.263236559	futex	<	multipathd	184	201			host	
299	0.263239428	clock_gettime	>	multipathd	184	201			host	
300	0.263240322	clock_gettime	<	multipathd	184	201			host	
301	0.263241816	clock_gettime	>	multipathd	184	201			host	
302	0.263242562	clock_gettime	<	multipathd	184	201			host	
303	0.263244922	write	>	multipathd	184	201	9		host	fd=9(<=)
304	0.263247726	write	>	multipathd	184	201	9		host	res=8 dat
305	0.263249207	write	>	multipathd	184	201	9		host	fd=9(<=)
306	0.263249604	write	<	multipathd	184	201	9		host	res=8 dat
307	0.263250393	write	>	multipathd	184	201	9		host	fd=9(<=)
308	0.263250508	write	>	multipathd	184	201	9		host	res=8 dat
309	0.263251227	clock_gettime	>	multipathd	184	201			host	
310	0.263251469	clock_gettime	<	multipathd	184	201			host	
311	0.263251843	clock_nanosleep	>	multipathd	184	201			host	
312	0.263252142	switch	>	multipathd	184	201			host	next=184(i
313	0.263252827	futex	<	multipathd	184	184			host	res=0
314	0.263260683	futex	>	multipathd	184	184			host	addr=5050h
315	0.263261977	futex	<	multipathd	184	184			host	res=0
316	0.263261734	futex	>	multipathd	184	184			host	addr=5050h

System Event 160: 74 bytes
Sysdig Event
Event Information
Event Arguments
Process Information
Process Ancestors
Container Information
User Information
Group Information

demo.scap

Events: 3797

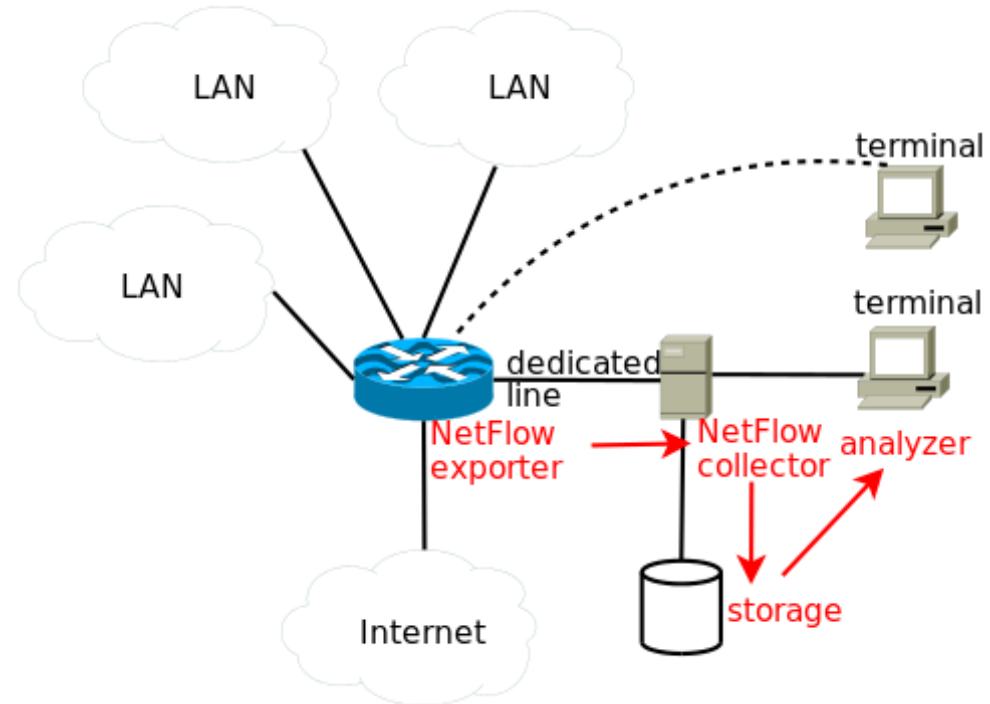
Profile: Default

Datenquellen – netflow (1)

- **NetFlow** ist ein Protokoll, welches als Tool für die Netzwerk-Fehlersuche und das session-based Accounting entwickelt wurde.
- **NetFlow** bietet eine wichtige Reihe von Diensten für IP-Anwendungen, einschliesslich Network Traffic Accounting, nutzungsbasierte Netzwerkabrechnung, Netzwerkplanung, Sicherheit, Denial-of-Service-Überwachungsfunktionen und Netzwerküberwachung.
- Darüber hinaus liefert es Informationen über Netzwerkbenutzer und -anwendungen, Spitzenauslastungszeiten und das Verkehrsrouting.
- Es zeichnet Informationen über den Paketfluss einschliesslich Metadaten auf. Cisco hat NetFlow ursprünglich entwickelt und es wurde als Basis für einen IETF-Standard namens **IPFIX** verwendet.
- **NetFlow**-Informationen können mit Tools wie dem **nfdump** angezeigt werden.
- nfdump ist ein Befehlszeilen-Dienstprogramm zum Anzeigen von NetFlow-Daten aus dem **nfcapd**-Capturedaemon bzw. Kollektor.

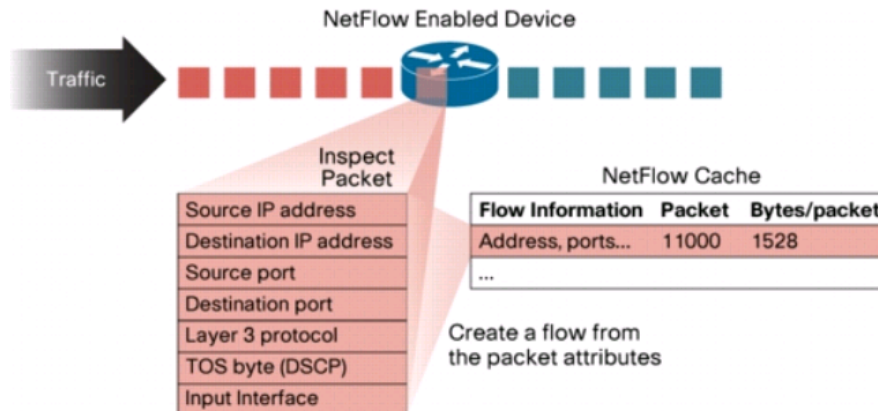
NetFlow Konzept

- Idee dahinter: sammeln von Informationen zu IP Datenströmen, welche anschliessend für **Traffic-** und **QoS-Analyse** oder **Kapazitätsmanagement** verwendet werden
- So kann z.B. schnell der "Top-Sender" ermittelt werden.



NetFlow - Arbeitsweise

- NetFlow sammelt die Verkehrsdaten und **aggregieren** diese.
- Viel Netzwerkgeräte unterstützen NetFlow bzw. eine Variante davon (jFlow, sFlow, etc.).



Anwendungsbeispiel: Top Talker

ntop

(C) 1998-2012 – Luca Deri

Search ntop...

About

Summary

All Protocols

IP

Utils

Plugins

Admin

Top Talkers: Last Hour

Time Period		Top Senders		Top Receivers	
1.	Fri Jul 24 13:58:00 2015	10.56.102.41	2.4 Mbit/s	10.56.102.41	1.2 Mbit/s
		a385....tweakers.atom86.net	3.1 Kbit/s	a385....tweakers.atom86.net	6.3 Kbit/s
	Fri Jul 24 13:58:59 2015	tweaking.net	2.5 Kbit/s	tweaking.net	5.0 Kbit/s
		tweakers.net	265.0 bit/s	tweakers.net	530.1 bit/s
		bam-1.nr-data.net	42.9 bit/s	bam-1.nr-data.net	85.7 bit/s
		10.56.102.41	2.6 Mbit/s	10.56.102.41	1.3 Mbit/s
		a385....tweakers.atom86.net	3.4 Kbit/s	a385....tweakers.atom86.net	6.7 Kbit/s

NetFlow

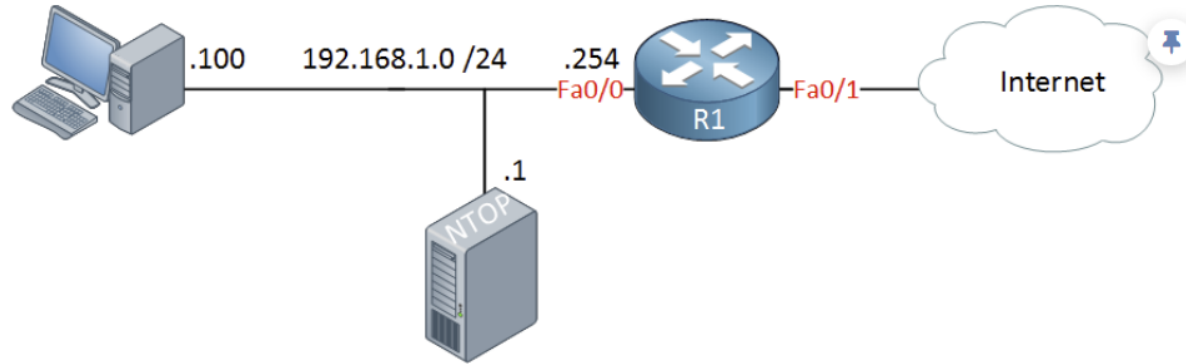
- Vormalig proprietäre Technik von Cisco, inzwischen unter leicht unterschiedlichen Namen (cFlow, jFlow für Juniper, Netstream für Huawei, etc.) von vielen Herstellern verfügbar.
- IPFIX (Internet Protocol Flow Information Export) ist von der IETF (Internet Engineering Task Force) als Weiterentwicklung des NetFlow-Protokolls von Cisco entwickelt worden.
- Es gibt verschiedene Kollektoren, auch frei verfügbare. Z.B. von PRTG (<https://www.paessler.com/tools/netflowtester>) oder SolarWinds (<https://www.solarwinds.com/free-tools/real-time-netflow-analyzer>)

Netflow - ipfix

- Es steht eine grosse Anzahl von Attributen für einen Flow zur Verfügung. Das IANA-Register der IPFIX-Entitäten* listet mehrere hundert auf, wobei die ersten 128 am häufigsten verwendet werden.
- NetFlow ist ein nützliches Werkzeug bei der Analyse von Netzwerksicherheitsvorfällen. Es kann verwendet werden, um eine Zeitachse der Kompromittierung zu konstruieren, das Verhalten einzelner Hosts zu verstehen oder die Bewegung eines Angreifers oder Exploits von Host zu Host innerhalb eines Netzwerks zu verfolgen.

* <https://www.iana.org/assignments/ipfix/ipfix.xhtml>

NetFlow Beispielkonfiguration (1)



```
R1(config)#ip flow-export destination 192.168.1.1 2055
```

```
R1(config)#ip flow-export version 9
```

```
R1(config)#ip flow-export source FastEthernet 0/0
```

NetFlow – on device Beispielausgaben

```
R1#show ip flow export
```

Flow export v9 is enabled for main cache

Export source and destination details :

VRF ID : Default

Source(1) 192.168.1.254 (FastEthernet0/0)

Destination(1) 192.168.1.1 (2055)

Version 9 flow records

433 flows exported in 28 udp datagrams

0 flows failed due to lack of export packet

0 export packets were sent up to process level

0 export packets were dropped due to no fib

0 export packets were dropped due to adjacency issues

0 export packets were dropped due to fragmentation failures

0 export packets were dropped due to encapsulation fixup failures

```
R1#show ip cache flow
```

IP packet size distribution (98406 total packets):

1-32	64	96	128	160	192	224	256	288	320	352	384	416	448	480
.000	.013	.000	.001	.000	.000	.000	.000	.000	.000	.000	.000	.000	.000	.000

512	544	576	1024	1536	2048	2560	3072	3584	4096	4608
.000	.000	.000	.010	.966	.000	.000	.000	.000	.000	.000

IP Flow Switching Cache, 278544 bytes

37 active, 4059 inactive, 680 added

10154 age polls, 0 flow alloc failures

Active flows timeout in 30 minutes

Inactive flows timeout in 15 seconds

IP Sub Flow Cache, 34056 bytes

37 active, 987 inactive, 680 added, 680 added to flow

0 alloc failures, 0 force free

1 chunk, 1 chunk added

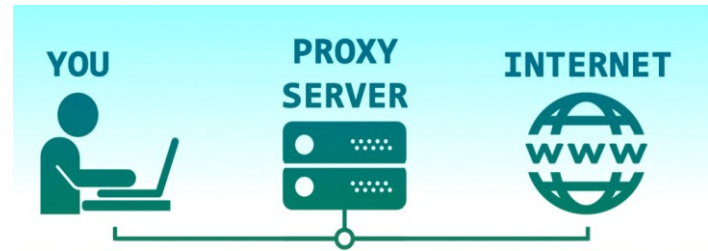
last clearing of statistics never

Protocol	Total	Flows	Packets	Bytes	Packets	Active(Sec)	Idle(Sec)
-----	Flows	/Sec	/Flow	/Pkt	/Sec	/Flow	/Flow
TCP-WWW	262	0.1	360	1479	41.1	3.2	8.6
TCP-other	153	0.0	21	1014	1.4	2.5	9.2
UDP-other	228	0.0	1	153	0.0	0.0	15.4
Total:	643	0.2	152	1461	42.7	1.9	11.2

SrcIf	SrcIPAddress	DstIf	DstIPAddress	Pr	SrcP	DstP	Pkts
Fa0/1	52.17.234.27	Fa0/0	10.56.102.41	06	0050	C1AA	1

SrcIf	SrcIPAddress	DstIf	DstIPAddress	Pr	SrcP	DstP	Pkts
Fa0/1	23.52.59.27	Fa0/0	10.56.102.41	06	0050	C21D	5
Fa0/1	8.8.8.8	Local	10.56.102.41	11	0035	F244	1

Datenquellen - Proxy Logs



- Proxyserver, wie sie für Web- und DNS-Anfragen verwendet werden, enthalten wertvolle Protokolle, die eine primäre Datenquelle für die Überwachung der Netzwerksicherheit darstellen.
- Der Proxyserver fordert die Ressourcen an und gibt sie an den Client zurück und generiert Protokolle aller Anforderungen und Antworten.
- Diese Protokolle können dann analysiert werden, um festzustellen, welche Hosts die Anfragen stellen, ob die Ziele sicher oder potenziell bösartig sind, und um auch Einblicke in die Art der heruntergeladenen Ressourcen zu erhalten.
- Web-Proxys liefern Daten, mit deren Hilfe festgestellt werden kann, ob Antworten aus dem Web als Reaktion auf legitime Anfragen generiert wurden oder ob sie so manipuliert wurden, dass sie als Antworten erscheinen, in Wirklichkeit aber Exploits sind.
- Es ist auch möglich, Web-Proxys zu verwenden, um ausgehenden Datenverkehr als Mittel zur Verhinderung von Datenverlusten (DLP) zu untersuchen.
- DLP beinhaltet das Scannen des ausgehenden Datenverkehrs um zu erkennen, ob die Daten die das Web verlassen, sensible, vertrauliche oder geheime Informationen enthalten.

Datenquellen - DNS Proxy Logs

Cisco Umbrella

- Cisco Umbrella, ehemals OpenDNS, bietet einen gehosteten DNS-Service, der die Fähigkeiten von DNS um Sicherheitsverbesserungen erweitert.
- Cisco Umbrella setzt viel mehr Ressourcen für die Verwaltung von DNS ein, als sich die meisten Unternehmen leisten können. Cisco Umbrella fungiert in dieser Hinsicht teilweise als "DNS-Superproxy".
- Die Umbrella-Suite wendet Echtzeit-Bedrohungsdaten auf die Verwaltung des DNS-Zugriffs und die Sicherheit von DNS-Einträgen an.
- Ein Beispiel für ein DNS-Proxy-Protokoll zeigt folgende Abbildung.

```
"2015-01-16 17:48:41","ActiveDirectoryUserName",  
"ActiveDirectoryUserName,ADSite,Network",  
"10.10.1.100","24.123.132.133","Allowed","1 (A)",  
"NOERROR","domain-visited.com.",  
"Chat,Photo Sharing,Social Networking,Allow List"
```




Datenquellen - Next Generation Firewalls

- Next-Generation- Firewalls erweitern die Netzwerksicherheit über IP-Adressen und Layer-4-Portnummern hinaus auf die Anwendungsschicht und darüber hinaus.
- NexGen Firewalls sind fortschrittliche Geräte, die viel mehr Funktionalität bieten als frühere Generationen von Netzwerksicherheitsgeräten.
- Eine weitere Funktionalität sind Reporting-Dashboards mit interaktiven Funktionen, die schnelle Point-and-Click-Reports zu sehr spezifischen Informationen ermöglichen, ohne dass SIEM oder andere Event-Korrelatoren erforderlich sind.
- NextGen Firewalls (NGFW) nutzen z.B. Cisco's Firepower Services, um mehrere Sicherheitsebenen in einer einzigen Plattform zu konsolidieren.
- Die Firepower-Services umfassen die Sichtbarkeit und Kontrolle von Anwendungen, Firepower Next-Generation IPS (NGIPS), reputations- und kategoriebasierte URL-Filterung und Advanced Malware Protection (AMP).

Datenquellen - Next Generation Firewalls

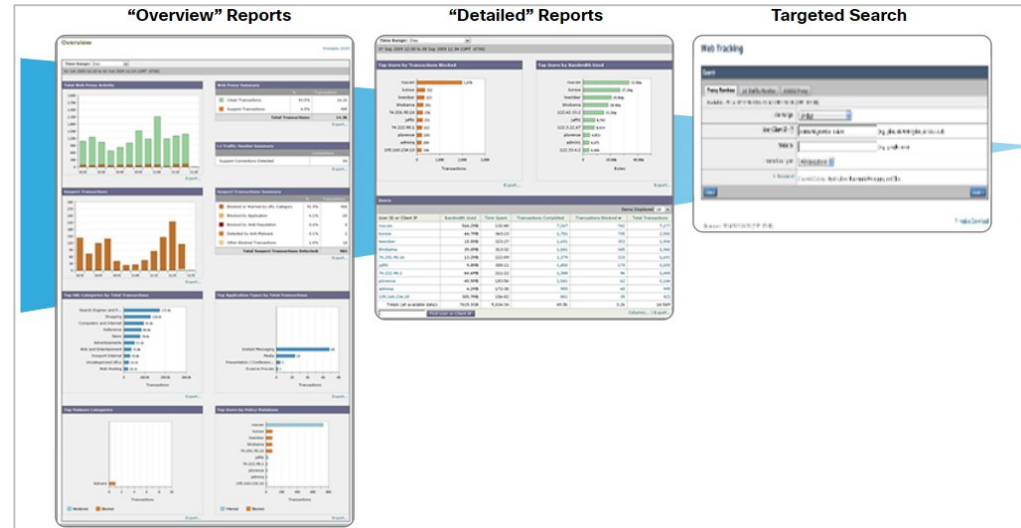
Übliche NGFW Events beinhalten:

- Connection Event
- Intrusion Event
- Host or Endpoint Event
- Network Discovery Event
- Netflow Event



Datenquelle – Content Filter Logs

- Geräte welche Content-Filterung anbieten, wie z. B. die Cisco Email Security Appliance (ESA) und die Cisco Web Security Appliance (WSA), bieten eine breite Palette von Funktionalitäten für die Sicherheitsüberwachung.
- Die Abbildung zeigt die Dashboards von Cisco Content-Filtering-Geräten. Durch Anklicken von Komponenten der Übersichtsberichte werden weitere relevante Details angezeigt. Die gezielte Suche liefert die fokussierten Informationen.



Datenquelle - Application Visibility

- Das Cisco ***Application Visibility and Control*** (AVC)-System kombiniert mehrere Technologien, um auf Netzwerkebene über 1000 Anwendungen zu erkennen, zu analysieren und zu steuern.
- Dazu gehören Sprach- und Video-, E-Mail-, File-Sharing-, Gaming-, Peer-to-Peer- (P2P) und Cloud-basierte Anwendungen.
- AVC nutzt die netzwerkbasierte Anwendungserkennung der nächsten Generation von Cisco, NBAR2 (Next-Generation NBAR), um die im Netzwerk genutzten Anwendungen zu erkennen und zu klassifizieren.
- Die NBAR2-Anwendungserkennungs-Engine unterstützt über 1000 Netzwerkanwendungen.

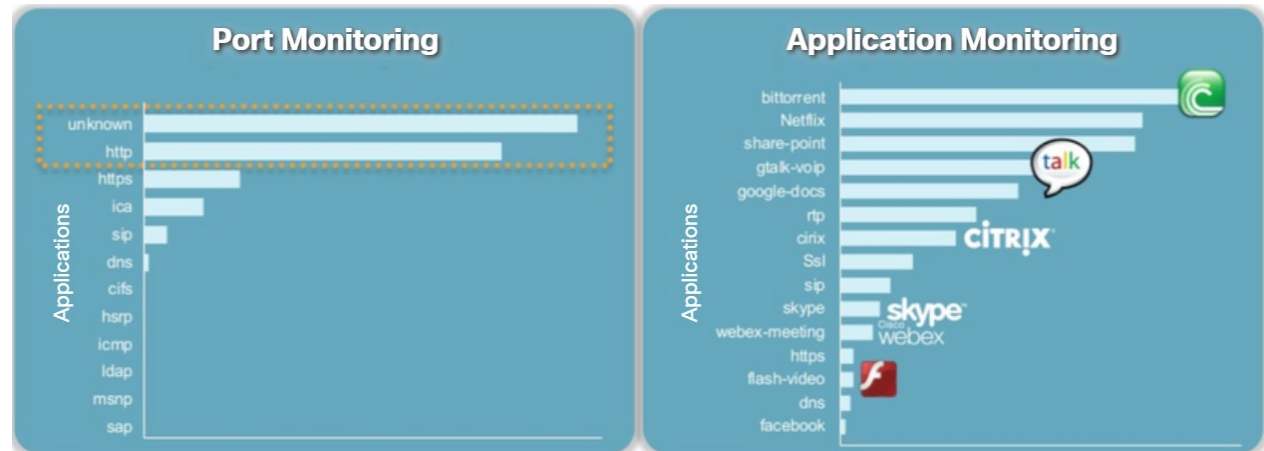
Datenquelle - Application Visibility

			
Application Recognition Zur Identifikation werden L3 – L7 Informationen ausgewertet • Cloud services • Cisco WebEx • YouTube • Skype • P2P	Metrics Collection Sammeln von Metriken welche ans Management Tool exportiert werden • Bandwidth usage • Response time • Latency • Packet loss • Jitter • P2P	Management and Reporting Bereitstellen des Netzwerks, Sammeln von Daten und Erstellen von Berichten über die Anwendungsleistung • Report generation • Policy Management	Control Kontrolle der Anwendungsnutzung zur Maximierung der Netzwerkleistung • Application prioritization • Application bandwidth enforcement
NBAR2	Netflow9 Flexible Netflow IPFIX	Cisco Prime oder andere 3 rd Party Software	QoS

Datenquelle - Application Visibility

Port-Überwachung vs. Anwendungsüberwachung

- Ein Management- und Reportsystem analysiert die Anwendungsdaten und stellt sie in Dashboard-Berichten dar, die vom NOC Personal verwendet werden können. Die Anwendungsnutzung kann auch durch Quality-of-Service-Klassifizierung und Richtlinien auf der Grundlage der AVC-Informationen gesteuert werden.

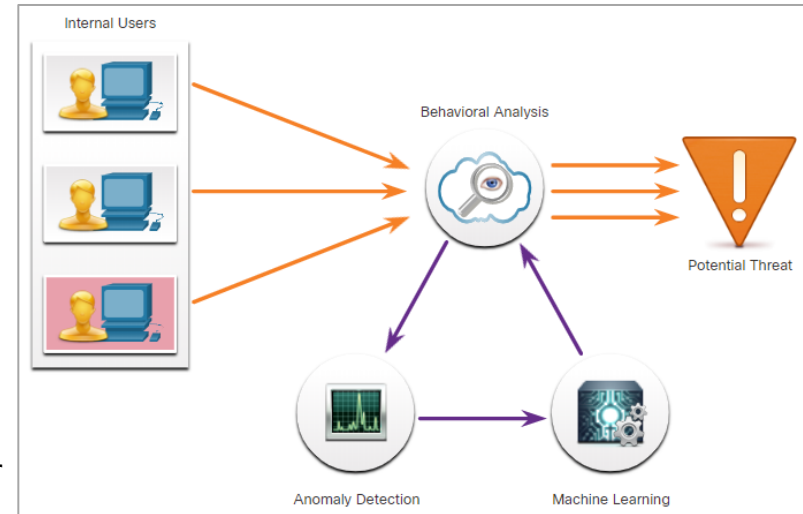




Statistische Daten

- Bei statistischen Daten handelt es sich um Netzwerkverkehr, der durch die Analyse anderer Formen von Netzwerkdaten erzeugt wird.
- Statistiken können verwendet werden, um normale Schwankungsbreiten in Netzwerkverkehrsmustern zu charakterisieren, um Netzwerkbedingungen zu identifizieren, die deutlich ausserhalb dieser Bereiche liegen.
- Ein Beispiel für ein NSM-Tool, das die statistische Analyse nutzt, ist Cisco Cognitive Threat Analytics.
- Es ist in der Lage, bösartige Aktivitäten zu finden, die Sicherheitskontrollen umgangen haben oder über nicht überwachte Kanäle (einschliesslich Wechseldatenträger) in das Netzwerk gelangt sind und innerhalb der Umgebung eines Unternehmens operieren.

Die Abbildung zeigt die Architektur für Cisco Cognitive Threat Analytics.



Alarm Daten

- Alarmdaten bestehen aus Meldungen, die von Intrusion-Prevention-Systemen (IPSs) oder Intrusion-Detection-Systemen (IDSs) als Reaktion auf Datenverkehr generiert werden, der eine Regel verletzt oder mit der Signatur eines bekannten Exploits übereinstimmt.
- Ein Netzwerk-IDS (NIDS), wie z. B. Snort oder Zeek, wird mit Regeln für bekannte Exploits konfiguriert.
- Alarme werden von Snort generiert und von den Anwendungen wie Sguil und Squert, welche Teile der **Security-Onion Suite** von NSM-Tools sind, lesbar und durchsuchbar gemacht.

SGUIL-0.9.0 - Connected To localhost

File Query Reports Sound Off ServerName: localhost UserName: analyst UserID: 22020-06-03 14:58:25 GMT

RealTime EventsEscalated Events

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
1	1	seconion...	5.1482	2020-05-10 21:20:55	209.165.201.17	52332	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite theme parameter remote file inclu
1	1	seconion...	7.1795	2020-05-10 21:20:55	209.165.201.17	52332	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phpSkelSite theme parameter remote file inclu
1	1	seconion...	7.1688	2020-05-10 21:20:52	209.165.201.17	52298	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phptraverse mp3_id.php GLOBALS Parameter F
1	1	seconion...	5.1375	2020-05-10 21:20:52	209.165.201.17	52298	209.165.200.235	80	6	ET WEB_SPECIFIC_APPS phptraverse mp3_id.php GLOBALS Parameter F
1	1	seconion...	5.1550	2020-05-10 21:21:17	209.165.201.17	52414	209.165.200.235	80	6	ET WORM TheMoon.lirakys.router 1
1	1	seconion...	7.1893	2020-05-10 21:21:17	209.165.201.17	52414	209.165.200.235	80	6	ET WORM TheMoon.lirakys.router 1
RT	4	seconion...	5.362	2020-05-10 20:58:01	209.165.200.235	6200	209.165.201.17	37071	6	GPLATTACK_RESPONSE is check returned root
RT	4	seconion...	7.675	2020-05-10 20:58:01	209.165.200.235	6200	209.165.201.17	37071	6	GPLATTACK_RESPONSE is check returned root
RT	12	seconion...	7.690	2020-05-10 21:20:25	209.165.201.17	52158	209.165.200.235	80	6	GPL_EXPLOIT_cnf access
RT	12	seconion...	5.377	2020-05-10 21:20:25	209.165.201.17	52158	209.165.200.235	80	6	GPL_EXPLOIT_cnf access
RT	8	seconion...	7.683	2020-05-10 21:20:25	209.165.201.17	52156	209.165.200.235	80	6	GPL_EXPLOIT_htr access
RT	8	seconion...	5.370	2020-05-10 21:20:25	209.165.201.17	52156	209.165.200.235	80	6	GPL_EXPLOIT_htr access
RT	1	seconion...	5.1055	2020-05-10 21:20:49	209.165.201.17	52238	209.165.200.235	80	6	GPL_EXPLOIT_readimgpawp2.htr access
RT	1	seconion...	7.1369	2020-05-10 21:20:49	209.165.201.17	52238	209.165.200.235	80	6	GPL_EXPLOIT_readimgpawp2.htr access

IP ResolutionAgent StatusSnort StatisticsSystem MsgsUser Msgs

☒ Reverse DNS☒ Enable External DNS

Whos Query: ☐ Name☐ Src IP☐ Dst IP

☒ Show Packet Data☒ Show Rule

Alert ip any any -> any (msg: GPLATTACK_RESPONSE is check returned root); content: "uid=0/root[2]"; host_pattern only; class:perl bad-unknown; rev: 2304080; rev: 0; metadata: created at 2010_09_23; updated at 2010_09_23; /usr/server/data/security/rules/seconion-ers192-3/download.rules: Line 700

IP	Source IP	Dest IP	Ver	HL	TOS	len	ID	Flags	Offset	TTL	Checksum
209.165.200.235	209.165.201.17	4	5	0	76	13818	2	0	64	53097	

TCP	Source Port	Dest Port	U A P R S F	R R C S S Y I	Seq #	Ack #	Offset	Res	Window	Urg	Checksum
	6200	37071	1	0	0	0	0	0	0	181	0

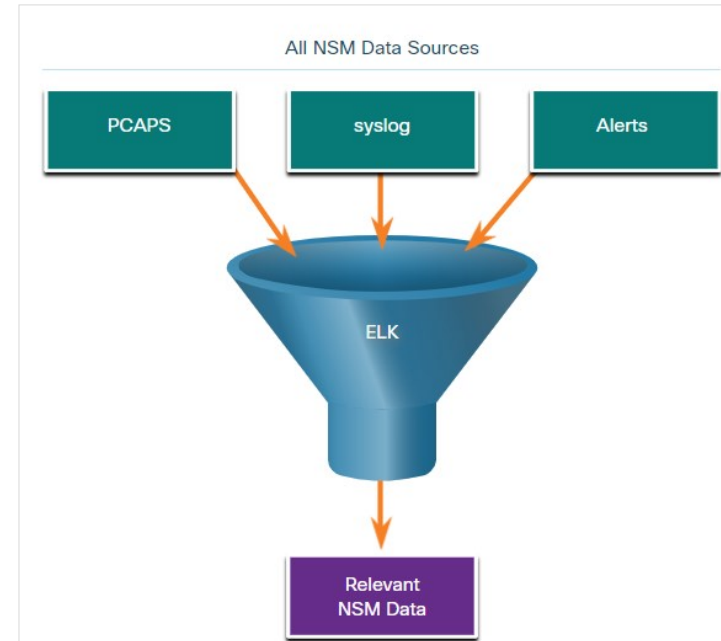
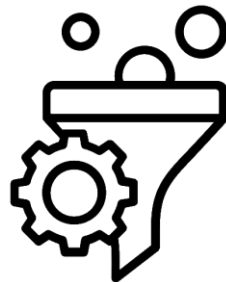
DATA	Source Port	Dest Port	U A P R S F	R R C S S Y I	Seq #	Ack #	Offset	Res	Window	Urg	Checksum
	75	69	64	30	30	28	72	6F	6F	74	29
	30	28	72	6F	6F	74	29	20	20	20	20

uid=0(root) gid=0(root).

Search Packet Payload☐ Hex☒ Text☐ NoCase

Datenreduktion (1)

- Um die Datenmenge zu reduzieren ist es wichtig, die Netzwerkdaten zu identifizieren, welche gesammelt und gespeichert werden sollten, um die Belastung der Systeme zu verringern.
- Durch die Begrenzung des Datenvolumens werden Tools wie Elasticsearch weitaus nützlicher sein.





Datenreduktion (2)

Datenreduktion erreichen mit:

- **Log-Level optimieren**

Setze nur notwendige syslog-Log-Level ein (z. B. INFO statt DEBUG im Produktivbetrieb). Reduziere besonders ausführliche Logs wie TRACE auf Entwicklungs- oder Testumgebungen.

- **Sampling**

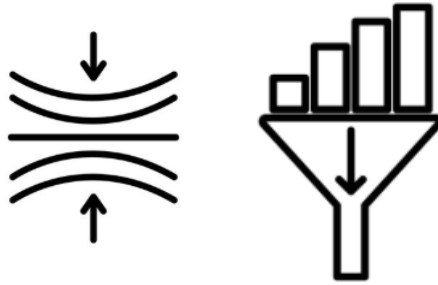
Nicht jedes Ereignis muss geloggt werden.

Beispiel: Nur 1 von 100 ähnlichen Requests loggen, wenn sie gleichförmig sind.

- **Aggregation statt Einzelereignisse**

Ähnliche oder repetitive Events zusammenfassen.

Beispiel: "5000 erfolgreiche Logins in den letzten 10 Minuten" statt 5000 einzelner Logzeilen.



Datenreduktion (3)

- **Filterung irrelevanter Daten**

Unnötige Felder entfernen (z. B. Debug-Parameter, redundante Metadaten). Nur sicherheits- oder betriebsrelevante Informationen behalten.

- **Strukturierte Logs verwenden**

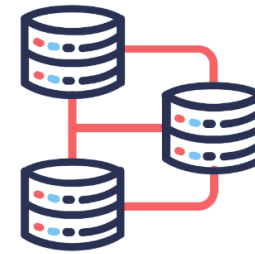
JSON oder andere strukturierte Formate erleichtern spätere Kompression und Analyse. Strukturierte Daten lassen sich effizienter deduplizieren.

- **Kompression**

Logs komprimieren (z. B. Gzip, Zstandard). Besonders effektiv bei repetitiven Logeinträgen, da die Entropie gering ist.

- **Retention Policies**

Alte Logs automatisch löschen oder in kostengünstigere Speicherklassen verschieben. Unterschiedliche Aufbewahrungszeiten für verschiedene Log-Typen definieren.



Daten Normalisierung (1)

- Bei der Datennormalisierung werden Daten aus verschiedenen Quellen in ein gemeinsames Format gebracht.
- In einem gemeinsamen Schema werden die Namen und Formate für die erforderlichen Datenfelder festgelegt.
- Zum Beispiel können IPv6-Adressen, MAC-Adressen sowie Datum und Uhrzeit in unterschiedlichen Formaten dargestellt werden:

IPv6 Address Formats	Mac Formats	Date Formats
2001:db8:acad:1111:2222::33	A7:03:DB:7C:91:AA	Monday, July 24, 2017 7:39:35pm
2001:DB8:ACAD:1111:2222::33	A7-03-DB-7C-91-AA	Mon, 24 Jul 2017 19:39:35 +0000
2001:DB8:ACAD:1111:2222:0:0:33	A70.3DB.7C9.1AA	2017-07-24T19:39:35+00:00

Vorteile: einfacher such- und vergleichbar (per pattern matching)

Daten Normalisierung (2)

Wie erreicht man eine Format-Normalisierung?

- **Einheitliche Datentypen erzwingen**

Strings → Strings

Zahlen → Zahlen

Datumswerte → echtes Datumsformat

Booleans → true/false

Beispiel: "01.02.2024", "2024/02/01" und "1 Feb 24" werden alle in ein Format wie YYYY-MM-DD überführt.

- **Standardisierte Einheiten verwenden**

Temperatur: K → °C oder umgekehrt

Längen: cm, m, km → eine einheitliche Einheit

Währungen: alles in CHF oder EUR

Beispiel: 5 km, 5000 m, 5'000.0 → alles in 5000 m.

Daten Normalisierung (3)

- **Formatierung von Text**

normalisieren Gross-/Kleinschreibung vereinheitlichen

Whitespace entfernen

Sonderzeichen bereinigen

Unicode-Normalisierung (NFC/NFD)

Beispiel: "Müller", "Müller" (mit kombiniertem Umlaut), "müller" → alle zu MÜLLER.

- **Strukturierte Formate erzwingen**

JSON validieren

CSV-Delimiter vereinheitlichen

XML-Schemas anwenden

Beispiel: CSV mit ; und , gemischt → alles auf , normalisieren.

Daten Normalisierung (4)

- **Kategorische Werte standardisieren**

Synonyme zusammen führen

Schreibvarianten vereinheitlichen

Codesysteme anwenden (z. B. ISO-Ländercodes)

Beispiel: "Schweiz", "CH", "Switzerland" → alles zu CH.

- **Numerische Werte normalisieren (Skalierung)**

Das ist besonders relevant für Machine Learning:

- **Min-Max-Scaling**: Werte in Bereich 0–1 bringen

- **Z-Standardisierung**: Mittelwert 0, Standardabweichung 1

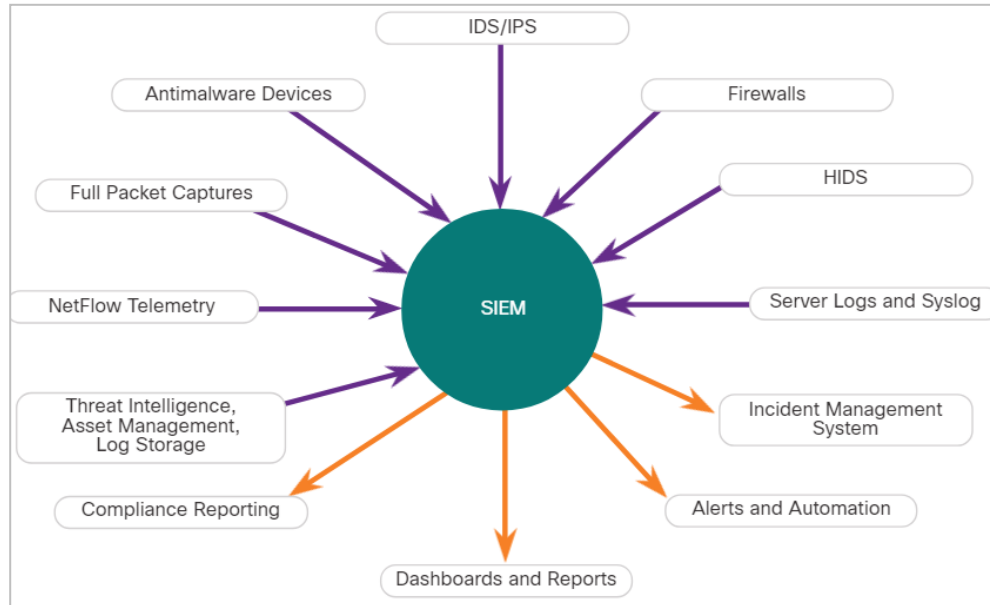
- **Log-Transformation**: bei stark schiefen Verteilungen

Beispiel: Einkommen 20'000–200'000 → skaliert auf 0–1.



Daten Kollektoren (SIEM)

Die SIEM-Technologie (Security Information and Event Management) wird in vielen Unternehmen eingesetzt, um Echtzeitreports und langfristige Analysen von Sicherheitsereignissen zu erstellen, wie in der Abbildung dargestellt.



SIEM Inputs and Outputs



SIEM und Logs

SIEM kombiniert die wesentlichen Funktionen von SEM- und SIM-Tools, um mithilfe der folgenden Funktionen einen Überblick über das Unternehmensnetzwerk zu erhalten:

- **Log-Collection** - Ereignisaufzeichnungen aus Quellen im gesamten Unternehmen liefern wichtige forensische Informationen und helfen bei der Erfüllung von Compliance-Reporting-Anforderungen.
- **Normalisierung** - Damit werden Protokollnachrichten aus verschiedenen Systemen in ein gemeinsames Datenmodell abgebildet, so dass das Unternehmen zusammenhängende Ereignisse miteinander verbinden und analysieren kann, auch wenn sie ursprünglich in unterschiedlichen Quellformaten protokolliert wurden.
- **Korrelation** - Diese Funktion verknüpft Protokolle und Ereignisse aus unterschiedlichen Systemen oder Anwendungen und beschleunigt die Erkennung von und die Reaktion auf Sicherheitsbedrohungen.
- **Aggregation** - Reduziert das Volumen der Ereignisdaten, indem doppelte Ereignisaufzeichnungen konsolidiert werden.
- **Reporting** - Hier werden die korrelierten, aggregierten Ereignisdaten in der Echtzeitüberwachung und in langfristigen Zusammenfassungen dargestellt, einschliesslich grafischer, interaktiver Dashboards.
- **Compliance** - Hierbei handelt es sich um ein Reporting, das die Anforderungen verschiedener Compliance-Vorschriften erfüllt.

SIEM und Logs

Ein beliebtes SIEM ist Splunk:
Die Abbildung zeigt ein Splunk Threat Dashboard. Splunk wird häufig in SOC's eingesetzt.

Aufgrund des Mangels an Cybersecurity-Fachleuten, welche die grosse Menge an Sicherheitsdaten überwachen und analysieren können, ist es wichtig, dass Tools/Daten von mehreren Anbietern in eine einzige Plattform integriert werden können. Integrierte Sicherheitsplattformen gehen über SIEM und SOAR* hinaus und vereinen mehrere Sicherheitstechnologien in einem einheitlichen Team.

*SOAR (Security Orchestration, Automation and Response)

Splunk Threat Dashboard

